

ناس لايف

فحص شامل لتطبيق ناس لايف

ترابط الخدمات، منطقية الخطوات، الأهمية للإطلاق، الهيكلية، مكامن الخلل والقوة،
وخارطة التطوير • 24 سبتمبر 2026

إعداد: عمرو حسن شعيب • Amr Hassan Shuaib

شركة أريب الرقمية • Areeb Digital

naslife.app

فحص شامل لتطبيق ناس لايف

تقرير موجّه للمؤسس عمرو حسن شعيب. تاريخ الفحص والفحوص الحية: 24 سبتمبر 2026 (قيم `/safety/status` و `/notify/status` وزمن التشغيل الحي المذكورة في القسم السادس أخذت في ذلك اليوم). كل ما يلي مبني على قراءة الكود في المستودع (`lib/` و `server/`) مع تثبيت كل ادعاء بموضعه `file:line`، وعلى تحقق مزدوج من كل مشكلة قبل إدراجها في القوائم المؤكدة. نواة الخادم (تسجيل الدخول، المستخدمون، نقل الرسائل، المقبس، اشتراكات الدفع الفوري، جدول `users`) تعيش خارج المستودع في `/opt/naslife/src`، ولذلك يُشار إلى كل ما يعتمد عليها بعبارة «النواة» (خارج المستودع).

مقاييس الدرجات في هذا التقرير: جداول الخدمات (القسم 2) والشخصيات (القسم 4) والأهلية (القسم 5) تستخدم مقياساً من 0 إلى 3 (0 = يجب إخفاؤه، 3 = صالح للإطلاق كما هو). بطاقات التماسك (2.1) والبنية (6.1) والأمن (7.1) تستخدم مقياساً من 0 إلى 10. في جداول المشكلات، العلامة † تعني بنداً من مسح التدفقات لم يخضع للتحقق المزدوج (مُدرج للاكتمال، خطورته تقديرية).

1. الملخص التنفيذي

ما يعمل جيداً

1. دفتر المحفظة وتسوية ميسر مبنيان بحذر تقني. كل تغيير رصيد يمر بمعاملة واحدة مع قفل `SELECT ... FOR UPDATE` على صف الحساب (`server/commerce.js:103-117`)، والمبالغ بالهللات في `BIGINT`. تسوية شحن البطاقة تُعاد قراءتها من ميسر بالمفتاح السري وتُفحص قيمتها وعملتها وتُقيّد مرة واحدة فقط (`server/market_b.js:376-401`)، والويبهوك يقارن السر بزمن ثابت.
2. الإضافات ذاتية الترحيل وتفشل بلطف. كل إضافة تنشئ جداولها وتُغلف بـ `try/catch` فتُعطل عند الخطأ بدل إسقاط الخادم، مع نقاط تشخيص تسهّل التحقق بعد النشر.
3. سوق المستخدمين حلقة كاملة. نشر، بحث، طلب بحجز المال، مراحل تنفيذ، رمز تسليم أو تأكيد أو إكمال تلقائي، عمولة، استرداد، نزاع، تقييم، إعلان مدفوع، مندوب، بازار، مع اختبارات ودجات وحزم خادم تغطي المسار.
4. الدوائر التجارية نموذج أدوار متسق (`owner/manager/staff/admin`) عبر دالة (`guard()`) واحدة (`server/business.js:199-225`)، وكتالوج مكتوب بأنواع حقيقية (سينما، عيادة، فندق، سيارة) ومساحة مجتمع مكتملة على نحو غير معتاد.
5. بطاقات الدردشة الذكية تُحلّ من الخادم لا من نص الرسالة (`server/chat_cards.js:81-148`)، و `Web Push` مبني بلا مكثبات خارجية لإعادة استخدام مفتاح النواة واشتراكاتها (`server/notify.js:22-44`).

أهم خمس مشكلات

6. الدوائر التجارية المبدورة بلا مالك تقبل دفعاً من المحفظة يذهب إلى لا أحد. `server/business.js:743-747` يخصم من العميل ويُقيّد للمالك فقط إن وُجد، بينما البذر يبقى `owner_id` فارغاً لـ 93 دائرة (34 في جدة و59 في الدمام) بأسماء علامات ومستشفيات حقيقية. مع الشحن التجريبي هذا مال وهمي؛ مع مفاتيح ميسر الحية يصبح قبض ثمن سلعة لن تُسلم أبداً.
7. رمز التسليم في السوق قابل للتخمين ويُقبل والطلب لا يزال `paid`. رمز من أربعة أرقام بلا عدّاد محاولات (`server/commerce.js:586,638-640`)، فيستطيع البائع تحرير مبلغ الضمان لنفسه قبل أي تسليم، وبعدها يفقد المشتري زر النزاع.
8. المال قابل للتكرار في سباقات مؤكدة. الاسترداد بلا شرط حالة داخل المعاملة (`server/commerce.js:646`) فيُرد مرتين عند إلغاءين متزامنين، والمخزون يُفحص خارج المعاملة ويُقصّ بـ (`GREATEST(0, ...)`) (564,592-593)؛ فيُباع آخر صنف مرتين، وإلغاء الفعالية يفشل بخطأ خادم إن أنفق المضيف الإيراد (299-307).

9. سكربت النشر التلقائي في المستودع لا يستطيع تحديث أي إضافة سبق نشرها، لأنه يمسح علامة «ملفنا» قبل فحصها

(server/autodeploy.sh:35,41,43). الإنتاج ينجو حالياً لأنه يشغل نسخة أقدم؛ أي تشغيل لـ `install`

`autodeploy.sh` يجمّد نشر الخادم بصمت. ولا يوجد أي نسخ احتياطي لقاعدة البيانات أو الوسائط.

10. لا شيء في الكود يفرض المسار التنظيمي الموصى به. التحويلات بين المستخدمين مفتوحة بلا سقف ولا مفتاح إطفاء،

الشحن التجريبي يُقيّد بنوع الحركة نفسه `topup` كأموال البطاقة، الحد الأدنى للشحن عشرة ريالات والأقصى الافتراضي

مئة ألف، وحذف الحساب الإداري يمحو دفتر المحفظة والطلبات.

الحكم العام على الجاهزية: المنصة غير جاهزة لأموال حقيقية ولا لمتاجر التطبيقات، لكنها قريبة من إطلاق اجتماعي محدود

(خريطة ومنشورات ودوائر للتصفح ودردشة بلا رموز مالية ومدونة) إذا أخفيت الخدمات المالية وأغلقت الثغرات العالية،

وأضيفت سياسة الخصوصية والشروط وحذف الحساب الذاتي. حزمة «سلامة المال» وإصلاح النشر والنسخ الاحتياطي تحتاج

أياماً لا أسابيع، ويجب أن تسبق أي مفتاح ميسر حي.

2. خريطة الخدمات وترابطها

الدرجة في هذا الجدول من 0 إلى 3 (جاهزية الخدمة للإطلاق كما هي).

الخدمة	الغرض	مدخل المستخدم	الخدمات التي تعتمد عليها	الحالة	الجاهزية (من 3)
القشرة والتنقل (lib/app/app.dart)	جلسة، خمسة تبويبات، روابط عميقة، وضع الراثر	فتح naslife.app	النواة (/ws , /me), share.js , notify.js	جزئي	3
الحسابات والملف (profile.js , auth_alias.js)	دخول بالبريد والبنك نيم، استعادة، صورة، روابط /u/	شاشة الدخول، ماي سبيس	النواة (/register , /login , /recover , /login mail.js)	جزئي	3
الخريطة والمنشئ (map_posts.js , tiles.js)	منشورات مكانية مؤقتة بصورة/فيديو/نص وصوت	تبويب الخرائط، زر «لحظتك»	chat_tools.js للرفع، OSM , safety.js	جزئي	2.5
الدوائر التجارية (business.js , biz_community.js , offers.js)	صفحة لكل نشاط مع كتالوج وطلبات ومجتمع وعروض	بطاقة الرئيسية، تبويب الدوائر (شريحة «تجارية»)	المحفظة، notify.js , safety.js	جزئي	1
الدوائر المجتمعية (النواة)	مجموعات أعضاء بمنشورات وتعليقات	تبويب الدوائر (الافتراضي)	النواة (/vessels/*), vessel_mod.js	جزئي	3
الفعاليات والتذاكر (commerce.js)	فعالية بفئات تذاكر تُدفع من المحفظة	بطاقة الرئيسية «الفعاليات»	المحفظة	جزئي	1.5
العروض والأمانيات والبحث (wishlist.js , offers.js , saved_search.js , search.js)	خصومات للأعضاء، تنبيهات، بحث موحد	صفحة الدائرة، ماي سبيس، زر البحث	business.js , notify.js	جزئي	2
السوق (commerce.js , market_plus.js , market_b.js)	بيع بين المستخدمين بحجز المال والعمولة	بطاقة الرئيسية «السوق»	المحفظة، safety.js , share.js	جزئي	1.5
المحفظة والمدفوعات (market_b.js , commerce.js)	دفتر داخلي، شحن تجريبي وبالبطاقة، تحويل	بطاقة الرئيسية «المحفظة»	ميسر، admin.js للإعدادات	جزئي	0.5
الردشة والإشعارات (chat_tools.js , notify.js , chat_cards.js)	وسائط وبطاقات ورموز مالية، إشعارات	تبويب المحادثات، الجرس	النواة (/messages , /push/*), المحفظة	جزئي	2.5
السلامة والإشراف (safety.js , vessel_mod.js)	كتم وحظر وبلاغات وكلمات محظورة وإخفاء تلقائي	قوائم المحتوى، ماي سبيس، لوحة الإدارة	النواة (/blocks , /reports), admin.js	جزئي	1.5
لوحة الإدارة ومساحة العمل (team.js , admin.js , inbox.js , tasks.js , blog.js , mail.js)	مستخدمون، بلاغات، مالية، فريق، مهام، بريد، مدونة	admin / أو ماي سبيس	كل الإضافات، Resend/SMTP، Anthropic	جزئي	3
البنية والنشر	مؤقت سحب، بناء الويب، Caddy، Postgres	المشغل	GitHub، الخادم الواحد	جزئي	1.5

تدفق القيمة بين الخدمات. المسار المقصود هو: الخريطة تجذب الزائر بالمحتوى المحلي، فيكتشف الدوائر التجارية والمجتمعية، ثم يشتري من الدائرة أو من السوق، وكل ذلك يمر بالمحفظة، وتغلق الدردشة الحلقة بالتفاوض والدفع. في الكود الفعلي الحلقة مقطوعة في مواضع محددة:

- **القشرة تخفي كل الخدمات المالية.** التبويبات الخمسة هي الرئيسية والخرائط والدوائر (المجتمعية) والمحادثات وماي سبيس (lib/app/app.dart:80-81)؛ السوق والفعاليات والمحفظة تُفتح من بطاقات الرئيسية فقط

(lib/pages/home/home_page.dart:104-108) أو من قائمة طويلة في ماي سبيس التي تعمل عملياً كخريطة موقع (lib/pages/myspace/myspace_page.dart:88-114).

- **المنشئ ينشر إلى الخريطة أو الدائرة التجارية أو السوق** (lib/pages/posts/composer/publish_page.dart:235-239) ولا يصل أبداً إلى الدوائر المجتمعية التي يعرضها التبويب الرئيسي، فلكل نوع منشور محرّر مختلف وصيغة غير متوافقة.
- **المحفظة محور لكن بلا روابط عائدة.** صف كشف الحساب لا يفتح الطلب الذي دفع ثمنه، وتاريخ المشتريات موزّع على أربع صفحات: «حجوزاتي وطلباتي» و«عروضي وطلباتي» و«تذاكري» و«عروضي» (الكوبونات).
- **ترقية البائع تنسخ عروض السوق إلى كتالوج الدائرة** (server/market_b.js:216-224) فيصبح للبائع كتالوجان غير مرتبطين بمحرّكي مال مختلفين: طلب الدائرة يُقَدّ للمالك فوراً، وطلب السوق يُحجز حتى الاكتمال.

نقاط الازدواج في المصطلحات (سبب مباشر لارتباك المستخدم الجديد): كلمة «دائرة» تعني ثلاثة أشياء (مجموعة مجتمعية، صفحة نشاط، مساحة نقاش داخل النشاط)، وكلمة «عرض» خمسة (وسم منشور، خبر نشاط، خصم/كوبون، عرض للبيع في السوق، إعلان مميز)، وكلمة «طلب» أربعة (طلب دائرة، طلب سوق، طلب مشتري، طلب دفع في الدردشة)، و«لحظة» اثنان (قصة النواة ووسم منشور الخريطة). البحث يسمّي الدوائر المجتمعية «دوائر» والأنشطة «أنشطة»، بينما الأمنيات تسمّي الأنشطة «دوائر تجارية».

المسرد المقترح (يُطبّق على الملصقات والرسائل والبريد والإشعارات):

المفهوم في الكود	المصطلح الموحّد المقترح	ما يستبدله
vessel (النواة)	مجتمع	«دائرة»، «دوائر» في الرئيسية
biz (صفحة نشاط)	دائرة تجارية (أو مكان)	«نشاط»، «أنشطة تجارية»، «دائرة»
biz_community	ساحة النقاش	«مساحة المجتمع»
map_posts	منشور	«لحظة» (تُحذف قصة النواة من قائمة النقطة)
market_listings	عرض للبيع	«عرض»
offers.js (deal/coupon/checkin/loyalty)	خصم / كوبون	«عرض»، «عروضي» في المحفظة → «خصوماتي»
spotlight	إعلان مميز	«سبوت لايت»
news kind biz_post	خبر	«منشور»
offer kind biz_post	يُدمج في offers.js (خبر يشير إلى خصم)	«عرض» كنص بلا أثر عند الدفع
market_orders / biz_orders	طلب (محجوز للمشتريات فقط؛ orderNoun للفتات)	«حجز» للمنتجات
market_wanted	أبحث عن...	«طلبات المشترين»
kind pay/split chat_requests	طلب دفع	«طلب»
الخريطة	الخريطة	«الخرائط» في التبويب
قسم الحساب في ماي سبيس	الحساب	«الأمان» في بريد الترحيب
صفحة الإشعارات	الإشعارات	«التنبيهات»

2.1 بطاقة التماسك بين الخدمات (من 10)

الخدمة	الدرجة	المبرر
القشرة والتبويبات	4	جلسة ووضع زائر متينان، لكن التبويبات تخفي كل الخدمات التجارية، وتبويب «الدوائر» يعرض الدائرة الأقل قيمة، ولا توجيه URL (app.dart:37-53, 80-81)

الخدمة	الدرجة	المبرر
منشورات الخريطة والمنشئ	6	تدفق كاميرا-أولاً متماسك بثلاث جهات، لكن «لحظة» تصطدم بقصص النواة، وتصفية الوسم غير مكشوفة، ولا رابط مشاركة، ومسارا الفيديو - المجتمع/السوق مكسوران (map_page.dart:389-392 , publish_page.dart:96,141)
الدوائر التجارية	4	كتالوج وأدوار غنية، لكن صفحة واحدة تخلط الدليل والمتجر والمجتمع والعروض، والمبذورات بلا مالك تقبض المال، ومحرك مال ثالث بقيد فوري (business.js:743-747)
الدوائر المجتمعية (النواة)	3	تحتل التويوب الرئيسي وبطاقة «دوائرك» بلا منشئ ولا روابط مشاركة ولا مال، وتشارك اسمها مع الصفحات التجارية (circles_page.dart:44-46)
السوق	5	دورة ضمان كاملة وتكاملات جيدة، لكنه يُفتح من بطاقة واحدة فقط، وروابط /l/ مية، ومفردات «عرض/طلب» تتصادم مع ثلاث خدمات، والترقية تفترق الكتالوج (market_b.js:216-224)
العروض والعضوية	5	نموذج خادم نظيف، لكن العميل يقابل خمسة أشياء اسمها «عرض»، والمستوى الافتراضي للإشعار لا يُطلق شيئاً، ورموز الأهلية تتسرب إلى الواجهة (offers_page.dart:192)
الفعاليات والتذاكر	3	جزيرة معزولة: بطاقة رئيسية والمحفظة فقط، المكان = موقع المنظم، لا استرداد، وسطح «طلباتي» ثالث (events_page.dart:103-108,280)
المحفظة	5	مركزية ومتسقة كدفتر، لكن واجهتها مُطلق لصفحات تاريخ من مجالات أخرى بلا روابط عائدة من صفوف الكشف (wallet_page.dart:62-68,226-243)
الدردشة والبطاقات الذكية	6	البطاقات تربط كل الكيانات جيداً؛ الأوامر المالية تكرر تحويلات المحفظة بتصادم «طلب»، وصندوق الطلبات المعقدة لا يراه أحد (chat_cards.js:271)
البحث والأمنيات والبحوث المحفوظة	5	أفضل غراء بين الخدمات، لكن ملصقات الشرائح نخالف كل الشاشات، ونوع biz في الأمنيات غير قابل للوصول (wishlist_api.dart:35 , search_api.dart:61)
الإشعارات والروابط العميقة	4	موجّه مركزي موجود، لكن نحو عشرين نوعاً بلا وجهة، وصفوف الدوائر مية، ونقر Push لا يعمل والتطبيق مفتوح (notify_open.dart:37-103)
ماي سبيس	5	يعمل كخريطة موقع فعلية (13 صفحاً) مما يثبت أن شريط التبويبات ناقص؛ ملصقاته تتصادم مع «عروضي» في المحفظة (myspace_page.dart:88-114)

3. تقييم كل خدمة على حدة

3.1 القشرة والتنقل (الرئيسية، البحث، الإشعارات، ماي سبيس، وضع الزائر)

الغرض. تقرر ما يراه الزائر (جدار دخول، عرض ضيفي لرابط مشارك، لوحة إدارة، أو التطبيق بخمسة تبويبات)، وتستعيد الجلسة من `localStorage`، وتفتح الروابط العميقة وأهداف الإشعارات.

خطوات المستخدم كما هي. الزائر يفتح `naslife.app` فيرى شاشة دخول زرّاء بشعار لاتيني؛ بعد التسجيل يظهر حوار ترحيب واحد ثم الرئيسية (تحية، شريط لحظات، بطاقة البث، أماكن رائجة، إجراءات سريعة، دوائرك، بث). في اللحظة نفسها يطلب المتصفح إذن الموقع من مزود `discoverProvider` ومن تبويب الخريطة المبني عند الإقلاع. الجرس يفتح صفحة الإشعارات؛ ماي سبيس يحوي ثلاثة عشر صفّاً إلى كل الخدمات. الروابط `/c/` و `/u/` تفتح للزائر عرضاً ضيفياً مع شريط «تتصفح كزائر».

منطقية الخطوات وما ينقصها. الجلسة متينة (تحقق `/me` عند الإقلاع، وضع دون اتصال، مزامنة بين التبويبات). لكن: لا تهيئة بعد التسجيل، طلب الموقع بلا سياق، لا توجيه URL فلا شيء قابل للإشارة المرجعية، الوضع الضيفي لا يُفتح إلا من روابط المشاركة، و رابط العرض `/l/` الذي يشاركه البائعون لا يعرفه العميل أصلاً.

نقاط القوة. إعادة بناء `apiClientProvider` لكل مستخدم فلا تسرّب بيانات بين الحسابات (`lib/state/app_state.dart:52-55`)؛ الوضع الضيفي يميّز القراءات الصامتة عن الأفعال التي تفتح ورقة الدخول (`lib/api/client.dart:246-267`)؛ موجّه إشعارات مركزي واحد (`lib/core/notify_open.dart`)؛ بحث يطبّع العربية ويكتشف أعمدة النواة عند الإقلاع.

المشكلات المؤكدة

العنوان	الخطورة	الدليل
روابط عروض السوق <code>/l/<id></code> لا تفتح العرض أبداً	عالية	<code>server/share.js:99-107</code> يقدّم المعايير؛ <code>lib/core/share/share_links.dart:24-35</code> يعرف <code>/c/</code> و <code>/u/</code> فقط؛ <code>lib/app/app.dart:253</code>
نقر إشعار Push والتطبيق مفتوح لا يفعل شيئاً	متوسطة	<code>web/push_sw.js:17-23</code> يستدعي <code>navigate</code> بجزء <code>#/n/<id></code> ؛ المعرّف يُقرأ عند الإقلاع فقط (<code>lib/state/notify_providers.dart:41-44</code>) ولا مستمع <code>hashchange</code>
طلب إذن الموقع في أول عرض بلا شرح	متوسطة	<code>lib/pages/home/home_page.dart:139</code> ← <code>lib/state/search_providers.dart:10-11,29-31</code> ← <code>lib/core/location.dart:18-19</code> ؛ <code>lib/pages/map/map_page.dart:83-86</code>
الخروج لا يبلغ اشتراك Push فالجهاز المشترك يستمر بتلقي إشعارات الحساب السابق	متوسطة	<code>lib/state/app_state.dart:169-174</code> ؛ <code>pushUnsubscribe</code> يُستدعى فقط من <code>lib/pages/myspace/myspace_page.dart:407</code>
«ملف خاص» لا يحترمه البحث ولا صفحة الرابط	متوسطة	<code>server/search.js:75-79</code> بلا <code>is_public</code> ولا استثناء للمحظورين؛ <code>server/share.js:94-95</code>
صفوف «جديد في دوائرك» بلا نقر والقائمة مقصودة عند أربعين	متوسطة	<code>lib/pages/notifications/notifications_page.dart:4</code> ؛ <code>DELETE /notify/:id</code> ؛ 8,81-96 بلا واجهة
شارة الجرس تجمع الدردشات غير المقروءة وطلبات الصداقة والإشعارات، لكن «تعليم الكل كمقروء» يسمح إشعارات التطبيق فقط فتبقى الشارة غير صفريّة †	منخفضة	<code>lib/app/app.dart:209-211</code> ؛ <code>notifications_page.dart:119-127</code>
توست «إضافة» يقول «أضيف إلى أصدقاؤك» في موضع و«أرسل طلب الصداقة» في آخر †	منخفضة	<code>notifications_page.dart:137</code> مقابل <code>user_profile_page.dart:173</code>
البحوث الأخيرة في <code>StateProvider</code> بالذاكرة وتضيع عند إعادة التحميل †	منخفضة	<code>lib/state/search_providers.dart:35-41</code>

العنوان	الخطورة	الدليل
اختبار شريحة نوع والحقل فارغ لا يغيّر شيئاً مرئياً؛ لا عدّاد نتائج ولا ترقيم بعد 30 في مجموعة مصنّفة †	منخفضة	search_page.dart:97-104, 110-122 server/search.js:67
السحب للتحديث يترك نصف الرئيسية قديماً	منخفضة	lib/pages/home/home_page.dart:33-41 مزوّدات فقط من ثمانية
الزائر الذي يضغط «مراسلة» يدخل شاشة دردشة مكسورة	متوسطة	lib/pages/profile/user_profile_page.dart:101 lib/api/client.dart:203, 261-263 chat_thread_page.dart:385
لا سياسة خصوصية ولا شروط ولا حذف ذاتي	متوسطة (عالية للمتاجر)	lib/screens/login_page.dart:193-216 server/admin.js:469-486 الحذف إداري فقط
عبارة الاسترداد تُرسل نصاً صريحاً في بريد الترحيب	متوسطة	server/auth_alias.js:115-131, 182-186

التطوير المقترح (بالأثر ثم الجهد) 1. تهيئة أول تشغيل: مدينة تغذي bboxProvider بدل جدة، شرح ثم طلب الموقع، اقتراح دوائر، صورة، اشتراك إشعارات (أثر عالٍ، أسبوع). 2. تصفح عام بلا حساب للرئيسية والخريطة والبحث مع جدار دخول عند الأفعال فقط؛ الآليات موجودة لروابط المشاركة (أثر عالٍ، أسابيع). 3. توجيه URL كامل (/u/, /c/, /v/, /p/, /e/, /l/). 4. حزمة امتثال المتاجر: سياسة hashchange مع (/n/؛ يصلح الرابط الميت ونقر Push في تصميم واحد (أثر عالٍ، أسبوع). 5. نظافة Push: إلغاء الاشتراك عند الخروج وشروط وموافقة عند التسجيل وحذف ذاتي وتصدير بيانات (أثر عالٍ، أسبوع). 6. صفحة إشعارات v2: ترقيم بـ before، سحب وتبديل الحساب، وطلب الإذن عند أول لحظة مفيدة (أثر متوسط، أيام). 7. تطبيق المسرد للحذف، صفوف الدوائر قابلة للنقر، ورقة تفاصيل للأنواع بلا وجهة، وشارة صادقة واحدة (أثر متوسط، أيام). 7. تطبيق المسرد الموحد (القسم 2) على الملصقات والرسائل والبريد؛ حفظ البحوث الأخيرة في localStorage وعدّاد نتائج وترقيم (أثر متوسط، أيام).

3.2 الحسابات والملف الشخصي

الغرض. حسابات نك نيم وكلمة سر مملوكة للنواة، مع طبقة في المستودع تضيف بريد الدخول، الاستعادة برمز البريد (بتخزين عبارة النواة مشفرة AES-256-GCM وإعادة تشغيلها إلى /recover)، تغيير كلمة السر، الصورة الشخصية، وصفحات OG لروابط المشاركة.

خطوات المستخدم كما هي. التسجيل بالبريد والنك نيم وكلمة السر (فحص توفر مباشر) ← POST /auth/register يستدعي النواة ويخزّن العبارة مشفرة ويرسل بريد الترحيب. الدخول بالبريد أو النك نيم. «نسيت كلمة السر» يرسل رمزاً من ستة أرقام ثم يعيّن كلمة سر جديدة. تغيير كلمة السر من ماي سبيس يتحقق بالنواة ثم يعيد تشغيل العبارة. الحسابات القديمة تفعل الاستعادة بإدخال العبارة وكلمة السر.

منطقية الخطوات وما ينقصها. الطبقة مكتملة ومختبرة (server/test/harness_auth_alias.mjs بنواة وهمية وSMTP وهمي). النواقص هيكلية: لا شاشة استعادة بالعبارة عند الدخول رغم أن كل الرسائل تحيل إليها، وتغيير كلمة السر مستحيل لحساب قديم بلا عبارة مخزّنة حتى بكلمة سر صحيحة، ولا معالجة لانتهاج الجلسة أثناء الاستخدام، وبريد غير مؤكد يحجب مالكة الحقيقي.

نقاط القوة. كلمات السر لا تلمس تخزين الإضافة؛ الأكواد مجزأة بمهلة وعدّاد محاولات؛ التبديل بين الحسابات يعيد بناء كل المزوّدات؛ صفحات المشاركة تُهرّب وتراعي الخصوصية (server/share.js:92-96)؛ ربط الخطأ بالعربية مركزي (lib/api/client.dart:282-326).

المشكلات المؤكدة

العنوان	الخطورة	الدليل
لا مسار استعادة بالعبارة داخل التطبيق (طريق مسدود للحسابات القديمة)	متوسطة	lib/screens/login_page.dart:10 server/auth_alias.js:219, 125, 292-301

العنوان	الخطورة	الدليل
الحسابات القديمة لا تستطيع تغيير كلمة السر بلا العبارة	متوسطة	server/auth_alias.js:272-273 يعيد no-recovery 409 ؛ النواة بلا مسار تغيير كلمة سر (خارج المستودع)
لا حذف ذاتي للحساب	عالية (تنظيمية)	lib/pages/myspace/myspace_page.dart:163-181 ؛ server/admin.js:469-486
لا سياسة خصوصية أو شروط أو موافقة	عالية (تنظيمية)	lib/screens/login_page.dart:193-216 ؛ لا مسار /privacy أو /terms في المستودع
الجلسة المنتهية لا تُعالج أثناء الاستخدام	متوسطة	lib/api/client.dart:259-266 يعالج 401 فقط عندما لا رمز؛ lib/state/app_state.dart:94-99 عند الإقلاع فقط
فشل حفظ localStorage يُبلغ كفشل دخول	متوسطة	lib/state/app_state.dart:123-126, 136-143
احتلال البريد: بريد غير مؤكد يحجب ماله ويُستخدم للدخول	متوسطة	server/auth_alias.js:85, 175, 197-201, 318-319
تغيير أو حذف بريد الدخول بلا إعادة توثيق ولا إشعار	متوسطة	server/auth_alias.js:314-333 ؛ myspace_page.dart:523, 543-544
رمز الجلسة في عنوان URL (الفاتورة وتصدير CSV)	متوسطة	server/market_plus.js:399-400 ؛ server/admin.js:604-606 ؛ lib/api/commerce_api.dart:55
تعداد الحسابات عبر /auth/forgot	متوسطة	server/auth_alias.js:211-225 (502 و 429 للبريد المسجل فقط)
قص كلمة السر غير متسق بين الدخول والتغيير	متوسطة	lib/api/client.dart:113, 163 يقص؛ 141, 154: لا يقص
مفتاح التشغيل نقطة فشل واحدة تفشل بصمت	متوسطة	server/auth_alias.js:30-38 يولد مفتاحاً مؤقتاً مع تحذير فقط
الزائر الذي يضغط «سجل الدخول» لا يعود إلى الصفحة	متوسطة	lib/app/app.dart:69, 256, 281, 298, 323
الملف الخاص يكشف حالة الاتصال والمعرف	منخفضة	lib/pages/profile/user_profile_page.dart:42, 84-85

التطوير المقترح 1. شاشة «استعادة بعبارة الاسترداد» تستدعي POST /recover ثم تخزن العبارة الجديدة، وتصحيح نصوص البريد (أثر عالٍ، أيام). 2. حذف ذاتي بإعادة توثيق كلمة السر مع إبقاء السجلات المالية مجهلة (أثر عالٍ، أسبوع). 3. صفحتا /privacy و /terms مع سطر موافقة (أثر عالٍ، أيام). 4. معالجة 401 عالمية مع لافتة «انتهت جلستك» وإعادة التحقق عند عودة التركيز، وخيار «الخروج من كل الأجهزة» (أثر عالٍ، أيام). 5. مسار تغيير كلمة سر في النواة وعدم حجب البريد غير المؤكد بعد يوم (أثر عالٍ، أسبوع، يعتمد على النواة). 6. حزمة أمن: عدم إرسال العبارة بالبريد، رموز تنزيل قصيرة العمر، حماية نقاط /status ، فشل صاحب عند تعذر حفظ المفتاح (أثر متوسط، أيام). 7. رؤية الجلسات والأجهزة: النواة تملك جدول sessions أصلاً (تقرؤه admin.js)؛ كشف GET /me/sessions و DELETE /me/sessions/:id وعرضها في ماي سبيس (الجهاز، آخر ظهور) مع بريد عند الدخول من جهاز جديد (أثر متوسط، أسبوع، يعتمد على النواة). 8. تغيير النك نيم مع إعادة توجيه الروابط: جدول تاريخ للأسماء حتى تُحوّل <القديم>/u/ وأكواد الدردشة؛ اليوم يغيره المدير فقط وتنكسر روابط المشاركة القديمة بصمت (أثر منخفض، أسابيع، يعتمد على النواة).

3.3 الخريطة والمنشئ والبث

الغرض. منشورات قصيرة مؤقتة (صورة/فيديو/نص مع طبقة صوت) تُلتقط بالكاميرا وتُعدّل بفلاتر تُخبز في الصورة، وتُنشر إلى الخريطة أو مجتمع دائرة أو السوق، وتُكتشف عبر الخريطة والبث العمودي والأماكن الرائجة، مع إحصاءات للناس ولمالك الدائرة.

خطوات المستخدم كما هي. زر «+» يفتح الكاميرا (تطلب الكاميرا والميكروفون معاً) – تعديل (نص، ملصق، قص، فلاتر، صوت) – شاشة نشر (تعليق، وجهة، مدة، تفاصيل احترافية) – رفع الغلاف ثم بقية الملفات – POST /mapposts. الخريطة تعرض نقاطاً ملونة بالوسم ولوحة منطقة؛ البث مرتب بالقرب والحدثة بترقيم OFFSET.

منطقية الخطوات وما ينقصها. التدفق سلس ومختبر، لكن تعديل منشور فيه صوت يمسح الصوت بصمت، ونص اللوحة يُقص من مئتين وثمانين إلى مئة وأربعين، والفديو إلى السوق ينتج عرضاً بلا صور، ولا واجهة إدارية لحجب أو استعادة منشور، ولا رابط مشاركة عام للمنشور، وشاشة النشر تقول «عند موقعك الحالي» بينما الموقع هو مركز الخريطة ولا يمكن تعديله.

نقاط القوة. تنقية صارمة على الخادم (cleanOverlays/cleanCta) وفحص كلمات محظورة على كل النصوص (server/map_posts.js:24-58, 134-135)؛ الفلاتر تُخيز قبل الرفع فيرى الجميع النتيجة نفسها؛ إسناد المكان الذكي (دائرة ضمن مئتين وخمسين متراً ثم اسم مكتوب ثم خلية)؛ وكيل بلاطات يحترم سياسة OSM؛ بدائل قابلة للحقن تجعل الاختبار الآلي ممكناً.

المشكلات المؤكدة

العنوان	الخطورة	الدليل
تعديل منشور فيه صوت يمسح الصوت بصمت	متوسطة	publish_page.dart:128 يرسل audioUrl: null؛ post_composer.dart:27-39 لا يستعيد الصوت؛ server/map_posts.js:272
نص اللوحة يُقتطع على الخادم بلا رسالة	متوسطة	server/map_posts.js:31 مقابل text_board.dart:96
لا واجهة إدارية لحجب/استعادة منشور خريطة	متوسطة	server/map_posts.js:395-404 بلا مستدع في lib/؛ server/admin.js:522-524
«متعدد» يرفع ثماني صور والمنشور يحتفظ بالغلاف فقط	متوسطة	server/map_posts.js:64؛ publish_page.dart:106-113, 123
فيديو إلى السوق ينشئ عرضاً بلا صور	متوسطة	publish_page.dart:96, 144-147, 239
الخادم يقبل أي رابط خارجي كوسائط	متوسطة	server/map_posts.js:103-109
تراكم بيانات وملفات يتيمة	متوسطة	server/map_posts.js:407, 287-289؛ لا حذف ملفات في chat_tools.js
ترقيم البث بـ OFFSET فوق ترتيب متغير	متوسطة	server/map_posts.js:204-205, 211
الكاميرا تطلب الميكروفون دائماً	متوسطة	lib/core/media/camera_web.dart:49, 55
التقدم التلقائي بسبع ثوانٍ يقطع الصوت	متوسطة	post_viewer.dart:73, 100-106
رقمان مختلفان للمشاهدات	متوسطة	server/map_posts.js:297-300, 338-340
موقع المنشور مضلل ومكشوف بدقة كاملة	متوسطة (تنظيمية)	server/map_posts.js:116, 154-165؛ publish_page.dart:320
السعر بالأرقام العربية-الهندية يصبح مجاناً	متوسطة	publish_page.dart:126, 145 parseSar موجود في commerce_models.dart:10-30 ولا يُستخدم هنا

التطوير المقترح 1. مشاركة المنشور برابط /p/:id مع معاينة OG وزر مشاركة في العارض (أثر عالٍ، أيام). 2. قسم إداري للمحتوى المكاني: قائمة المبلّغ عنه والمحجوب مع حجب/استعادة/حذف (أثر عالٍ، أيام). 3. فحص الصور والفديو قبل النشر وحد يومي لكل مستخدم (أثر عالٍ، أسبوع). 4. مؤشر keyset للبث وتصفية bbox مسبقاً وجلب المستخدمين دفعة واحدة (أثر متوسط، أيام). 5. شرائح تصفية بالوسم على الخريطة (الخادم يدعم tag ?) (أثر متوسط، أيام). 6. صور متعددة للمنشور (images JSONB) بدل إهدار اللقطات (أثر متوسط، أسبوع). 7. جامع قمامة للوسائط والجداول التابعة (أثر متوسط، أيام). 8. دبوس قابل للسحب وخيار تعقيم الموقع (أثر متوسط، أيام). 9. حفظ موضع البث و«شاهد» عبر الجلسات (اليوم viewed _ في الذاكرة فقط) مع «جديد منذ زيارتك» وإشعار مجمّع «أصداقاًك نشروا قريبك» عندما ينشر أحد جهات الاتصال ضمن كيلومترين (أثر منخفض، أسبوع). 10. النشر باسم الدائرة (author_biz على منشور الخريطة يُظهر شعار الدائرة كناشر) وربط إحصاءات الدائرة به بدل الاعتماد على cta.value=slug فقط (map_posts.js:376) (أثر متوسط، أسبوع).

3.4 الدوائر التجارية والمجتمعية والفعاليات

الغرض. صفحة لكل نشاط محلي بكتالوج مكتوب (منتج، فيلم، غرفة، سيارة، عيادة، معلومات) يُشترى ويُحجز من المحفظة برمز QR يُستخدم عند الاستلام، ومساحة مجتمع، وانضمام للعروض، وتقييمات، ولوحة مالك بثماني تبويبات. **93 دائرة مبدورة (34 لجة و59 للدمام)** قابلة للمطالبة؛ عيادات المستشفيات المبدورة بسعر 0 (business_seed.js:11) فلا تحرك مالا. الفعاليات تتيح لأي مستخدم بيع تذاكر تُدفع من المحفظة. الدوائر المجتمعية مجموعات أعضاء من النواة.

خطوات المستخدم كما هي. العميل يتصفح القائمة (تصنيف، مفتوح الآن، الأقرب) ← صفحة النشاط ← بطاقة الصنف ← ورقة كمية ثم «ادفع من المحفظة» (السينما والعيادة تخصصان فوراً بلا ورقة تأكيد) ← الخادم يقفل الصنف ويطبق أفضل عرض ويخصم من العميل ويُقيد للمالك فوراً ← ورقة طلب بـ QR ← الطاقم يدخل الرمز يدوياً. المالك ينشئ الدائرة من ماي سبيس ويدير الكتالوج والطلبات والمنشورات والتقييمات والفريق ونقل الملكية. الفعاليات: نموذج واحد بفئة واحدة وإحداثيات من موقع المنظم.

منطقية الخطوات وما ينقصها. الهندسة جيدة لكن التشغيل بالمال خطر: الطلب على الدوائر بلا مالك يُخصم ولا يُقيد لأحد، الاسترداد يُخصم من مالك اللحظة لا ممن قبض له، البذر يعيد المخزون والتفعيل عند كل إقلاع، التقييم بلا شراء، نقل الملكية بلا قبول، المحرر لا يختار نوع الصنف، ومهلة الإلغاء غير مرئية. الفعاليات جزيرة معزولة بلا تعديل ولا استرداد للمشتري.

نقاط القوة. إنشاء الطلب معاملة بقفل على الصنف فلا حجز مزدوج (server/business.js:703-751)؛ أنواع الكتالوج تغطي احتياجات حقيقية (عروض سينما مولدة يومياً بمقاعد متبقية، عيادات بأيام وسعة)؛ بحث عربي وتحليل ساعات عمل؛ مساحة المجتمع مكتملة (مواضيع، اقتباس أصناف، صوت، تفاعلات، تثبيت، إخفاء، بلاغات) مع ثلاثة عشر اختباراً؛ الإشعارات موصولة لكل حدث مع رابط عميق.

المشكلات المؤكدة

العنوان	الخطورة	الدليل
الدوائر المبدورة بلا مالك تقبل دفعاً يذهب إلى لا أحد	عالية (رُشحت حرجة؛ انظر ملاحظة 9.1)	server/business.js:743-747 business_seed.js:17,93,141 business_seed_dammam.js:94: التحذير سطر رمادي business_page.dart:187-193 (ملاحظة: مدير المنصة يستطيع تقنياً الإلغاء والاسترداد 833-848: ، وعيادات المستشفى المبدورة مجانية business_seed.js:11)
الاسترداد يُخصم من مالك لحظة الإلغاء لا ممن قبض له	عالية	server/business.js:746,775,784,676-687,457-458
القيد الفوري للمالك والطلب ما زال قابلاً للاسترداد فتهدد الأرضة تحت الصفر	متوسطة	server/business.js:746,312-318,784
النقاط تُمنح عند الشراء ولا تُعكس عند الاسترداد	متوسطة	server/business.js:744,783
البذر يعيد المخزون والتفعيل عند كل إقلاع	متوسطة	server/business.js:126-129,138-141,144
السينما والعيادة تخصصان بلا تأكيد	متوسطة	business_page.dart:1013-1026,831-845 مقابل 307-319:
مهلة الإلغاء غير مرئية والمنتج يُسمى «حجز»	متوسطة	business_page.dart:468,492,496
المحرر لا يختار نوع الصنف	متوسطة	dashboard_catalog.dart:111,298 business.js:544 kind في
أي أحد يقيم بلا شراء وإعادة التقييم تسمح رد المالك	متوسطة	server/business.js:517-528
نقل الملكية بلا قبول	متوسطة	server/business.js:676-687

العنوان	الخطورة	الدليل
المطالبة بملكية دائرة علامة حقيقية بلا أي دليل (سجل تجاري/هاتف) وقبولها لا يمنح شارة التوثيق	متوسطة	server/business.js:435-447 (نص حر)، 448-466: (القبول يضبط owner_id فقط)، 467-473: (التوثيق مسار إداري منفصل)
إلغاء الفعالية بلا تأكيد وإحداثيات المنظم وبغسل بخطاء خادم إن أنفق الإيراد	عالية (خريطة الدوائر قَدَرَتها متوسطة كتجربة؛ المحفظة والجاهزية والشخصيات عالية لأن مسار المال يغسل ب500 ولا يُسترد لأحد)	events_page.dart:103-108, 189, 213-220 server/commerce.js:107, 299-303
استعلامات N+1 على أثقل المسارات	متوسطة	server/business.js:299, 486, 495-496, 813-814
لا دفتر تسوية للمالك والإيراد إجمالي	متوسطة	business_dashboard_page.dart:114, 130: لا مسار سحب
مرشّح «مفتوح الآن» يُطبّق بعد 200 LIMIT ، وكل مقاهي جدة المبدورة ساعاتها " " فلا يُعيد شيئاً †	متوسطة	business_seed.js:232 : server/business.js:357
مرشّح «القادمة» عند المالك يحتفظ بطلبات المنتجات غير المستلمة إلى الأبد †	منخفضة	server/business.js:809
لا ماسح QR؛ إدخال الرمز يدوي †	منخفضة	dashboard_orders.dart:178-189
بحث q في الخادم لا يستخدمه العميل (يبحث محلياً في 300 صف فقط) †	منخفضة	lib/state/biz_providers.dart:42 server/business.js:806
حقل ملاحظة العميل موجود في الخادم والعميل يرسل note: '' دائماً †	منخفضة	lib/api/biz_api.dart:23

التطوير المقترح 1. منع الطلب على الدوائر بلا مالك (not-orderable) مع وضع «معلومات فقط» وشارة «بيانات استرشادية» وسكربت استرداد للطلبات القائمة (أثر عالٍ، أيام). 2. تخزين credited_to على الطلب وحجز المال حتى الاستلام أو انقضاء مهلة الإلغاء، مع حالات اختبار طلب ← نقل ← إلغاء (أثر عالٍ، أسبوع). 3. تبويب تسويات للمالك ولافتة صادقة عن حالة السحب (أثر عالٍ، أسبوع). 4. ورقة تأكيد موحدة تعرض «يمكن الإلغاء حتى» والعرض الذي سيُطبّق، وحقل ملاحظة العميل (أثر متوسط، أيام). 5. منتقي نوع في محرر الكتالوج وأيام العيادة (أثر متوسط، أيام). 6. سياسة بذر: ON CONFLICT DO NOTHING أو seed_version، تحويل عروض السينما والعيادات المبدورة إلى غير قابلة للطلب حتى المطالبة، ملء ساعات المقاهي (أثر متوسط، أيام). 7. الفعاليات v2: منتقي مكان، استرداد للمشتري، تعديل، فئات متعددة، حجز إيراد التذاكر حتى الموعد (أثر متوسط، أسابيع). 8. اشتراط طلب مكتمل للتقييم ومنع تقييم الطاقم وجعل النقل دعوة؛ قائمة أدلة للمطالبة ومنح التوثيق تلقائياً عند القبول الموثّق (أثر متوسط، أسبوع). 9. ماسح QR للاستلام (مشارك مع تذاكر الفعاليات)، وتمرير q للخادم في بحث الطلبات، وانتهاء تلقائي لطلبات المنتجات غير المستلمة (أثر متوسط، أيام). 10. كتابة docs/business.md وتوسيع الحزم (أثر منخفض، أيام).

3.5 العروض والعضوية والأمنيات والبحوث المحفوظة والبحث الموحد

الغرض. الانضمام للدائرة هو العضوية، وأربعة أنواع عروض (خصم، كوبون، عند الحضور، ولاء) تُطبّق تلقائياً على الطلبات، مع إهداء الكوبون لصديق. حول ذلك قائمة أمنيات بتنبهات انخفاض السعر، وبحوث محفوظة تُفحص كل عشر دقائق، وبحث موحد عبر الأنشطة والأصناف والأشخاص والدوائر والسوق والفعاليات.

خطوات المستخدم كما هي. بطاقة «عروض سارية» على صفحة الدائرة ← صفحة العروض بأهلية لكل بطاقة ← عند الشراء يختار الخادم أفضل عرض مؤهل داخل معاملة الطلب ويظهر التوفير في ورقة الطلب لاحقاً. المالك ينشر من ستة قوالب.

الأمنيات بقلب على الأصناف والعروض والفعاليات والمنشورات. حفظ البحث من شريط أسفل الشرائح.

منطقية الخطوات وما ينقصها. النموذج متماسك ومختبر بأكثر من ستين فحصاً، لكن: المستوى الافتراضي لإشعارات الأعضاء near غير منقذ فأغلب الأعضاء لا يصلهم شيء بينما الواجهة تعد بالعكس؛ لا معاينة للعرض قبل الدفع ولا خيار رفضه؛ إهداء الكوبون ليس معاملة فعلية؛ البحث بلا فهارس ويكشف كل المستخدمين بلا دخول.

نقاط القوة. الأهلية مركزية بأسباب صريحة تُترجم بالعربية (server/offers.js:98-128)؛ منح الولاء متكررة الأمان بفهرس جزئي فريد؛ لقطات الأمنيات تُعاد قراءتها من المصدر فلا تُزور؛ التطبيق العربي مشترك بين البحث والبحوث المحفوظة والعميل.

المشكلات المؤكدة

العنوان	الخطورة	الدليل
إهداء الكوبون غير ذري (BEGIN/COMMIT عبر pool.query) وفحوص خارج القفل	عالية	server/offers.js:303-307,309-314
المستوى الافتراضي near غير منقذ رغم وعود الواجهة	متوسطة	server/offers.js:55,66,183-185 business_page.dart:252 offers_page.dart:20,326
لا معاينة ولا رفض للعرض قبل الدفع؛ كوبون 20% لمرة واحدة يُستهلك على أصغر طلب مؤهل بلا وسيلة لادخاره	متوسطة	business_page.dart:305-318,367 biz_api.dart:31 يدعم offerId server/offers.js:143-150
البحث الموحد مسح كامل بلا فهارس من حرف واحد وبلا دخول	متوسطة	server/search.js:63-64,70-72,75-110 saved_search.js:85-100
بحث الأشخاص يتيح تعداد المستخدمين بالنبذة	متوسطة	server/search.js:64,67,75-79
المحرر يقدم أنواع قيم يرفضها الخادم والخطأ يظهر خاماً	متوسطة	dashboard_offers.dart:261-264 server/offers.js:14,322
سقوف العروض تُفحص بلا أقفال	متوسطة	server/offers.js:101-102,107,114,120,154
سقف الإشعار اليومي مشترك بين الأنواع والمالك يُخبر دائماً بالوصول	متوسطة	server/offers.js:185-188 dashboard_offers.dart:501
رمز first-order الخام يُعرض للمستخدم	متوسطة	server/offers.js:117-118,277 offers_page.dart:192
عروض الحضور تعتمد على طلب موقع منتصف الدفع	متوسطة	business_page.dart:365-367
شريط حفظ البحث على تبويبي الأشخاص والدوائر وإعادة الحفظ تكتب بصمت	متوسطة	search_page.dart:94,382-384 saved_search.js:119-123
«عروضي» وعروض الدائرة N+1	متوسطة	server/offers.js:216-233,243-244,272-276
الهدايا تتجاهل الحظر والإيقاف	متوسطة	server/offers.js:292-318
الزائر الذي يرى خصماً عاماً يقرأ «غير متاح الآن» لأن eligible=false بلا lockedReason +	منخفضة	offers_page.dart:190-191 server/offers.js:223
مالك الدائرة الموقوفة يحصل على 404 في كل مسارات manage/offers (لا includeInactive +)	منخفضة	server/offers.js:64,70

التطوير المقترح 1. خطوة تسعير قبل «ادفع» مع مفتاح «بلا عرض» ومؤشر «أنت ضمن نطاق العرض» ومنتقي عند تعدد العروض المؤهلة (أثر عالٍ، أسبوع). **2.** جعل الافتراضي all وتصحيح النصوص وفصل السقف حسب النوع وعرض العدد المُخطر للمالك (أثر عالٍ، أيام). **3.** فهارس pg_trgm وحد أدنى حرفين وترتيب بالصلة (أثر عالٍ، أسبوع). **4.** معاملة حقيقية للإهداء وقفل صف العرض قبل عد السقوف (أثر عالٍ، أيام). **5.** تجميع مسارات قراءة العروض؛ تمرير includeInactive لمسارات الإدارة؛ ترجمة حالة الزائر (أثر متوسط، أيام). **6.** بحوث محفوظة قابلة للتعديل وتطبيق المسرد الموحد (أثر متوسط، أيام).

3.6 السوق

الغرض. سوق محلي بين المستخدمين: نشر عروض، دفع من المحفظة بحجز المال، سلسلة حالات أمامية فقط برمز تسليم أو تأكيد المشتري، عمولة عند الاكتمال، نزاعات يحسمها المدير، سبوت لايت مدفوع، بازارات موسمية، مندوب توصيل، ترقية البائع إلى دائرة.

خطوات المستخدم كما هي. المشتري يفتح السوق من الرئيسية ← بطاقة العرض ← يختار المتغير والكمية ← حوار «ملاحظة للبائع» بزر «تأكيد الطلب» يخصم المحفظة فوراً ← حوار «تم الطلب» بالرمز ← صفحة الطلب بمخطط زمني وأزرار «تأكيد الاستلام» و«إلغاء» و«فتح نزاع» متاحة معاً في حالة paid. البائع يتقدم بالمراحل ويدخل رمز المشتري أو ينتظر التأكيد أو الإكمال التلقائي بعد ثلاثة أيام. البائع ينشر من نموذج يُغلق قبل رفع الصور وإحداثيات جهازه.

منطقية الخطوات وما ينقصها. الحلقة كاملة، لكن بالمال الحقيقي: رمز التسليم قابل للتخمين ويُقبل قبل التسليم، الاسترداد بلا حراسة حالة، المخزون يُباع فوق الحد، أموال المشتري تتجمد بلا مهلة بعد «بدء التحضير»، العرض المرفوض طريق مسدود، لا عنوان توصيل، النزاع أحادي الجانب بلا تدقيق، وبائعون وهميون يُزرعون في الإنتاج عند كل إقلاع (27 حساباً تُسجل عبر /register في النواة بترويسة x-forwarded-for مزيغة لتجاوز حد المعدل، server/market_seed.js:21-28).

نقاط القوة. حجز المال وكل حركة مالية داخل معاملات مع قفل صفوف، والإكمال متكرر الأمان عبر UPDATE ... WHERE RETURNING (...) status IN (server/commerce.js:620-631)؛ آلة حالات أمامية فقط مع دور مندوب مقيد؛ إكمال تلقائي بعد ثلاثة أيام؛ حماية من الإساءة (سقف عروض للحساب الجديد، حارس تكرار، فلتز أرقام التواصل، مراجعة الحسابات الجديدة)؛ السبوت لايت موصول بالدفتر بحساب منصة؛ سمعة البائع محسوبة لا مُعلنة؛ تكامل واسع (روابط، بطاقات دردشة، طبقة خريطة، أمنيات).

المشكلات المؤكدة

العنوان	الخطورة	الدليل
رمز التسليم قابل للتخمين ويحرر المال قبل التسليم	عالية	server/commerce.js:586,638-640,623-626,675
أموال المشتري تتجمد بلا حد بعد «بدء التحضير»	متوسطة	server/commerce.js:663,613,710-718
الدفع من حوار «ملاحظة للبائع» بلا ملخص كامل ولا مسار شحن	متوسطة	listing_page.dart:147,150,162-163,19 (الملخص جزئي على زر الطلب؛ ينقص الرصيد ومسار الشحن)
لا حساب ضمان في الدفتر	متوسطة	server/commerce.js:589,625-626 admin.js:586
بيع فوق المخزون (سباق)	متوسطة	server/commerce.js:564,571-572,592-593
العرض المرفوض blocked نهائياً بلا إعادة تقديم	متوسطة	server/market_plus.js:448 server/commerce.js:493
تعيين مندوب بلا موافقته يكشف بيانات المشتري	متوسطة	server/market_b.js:76-82 server/commerce.js:519-521,529
رمز الجلسة في رابط الفاتورة	متوسطة	lib/api/commerce_api.dart:55 server/market_plus.js:400
التقسيم في النزاع يُسقط العمولة ويترك العمود كما هو	متوسطة	server/commerce.js:697-703 مقابل 691-696
بائعون وهميون في الإنتاج والفاتورة بلا عناصر ضريبية	متوسطة	server/market_seed.js:21-28,124 server/market_plus.js:411-418
النزاع أحادي الجانب وبلا تدقيق	متوسطة	server/commerce.js:670-708 naslifeAudit بلا
الإلغاء بلا تأكيد والبائع يلغي طلباً مسلماً	متوسطة	orders_page.dart:249,259,297-299 server/commerce.js:663
نشر العرض بلا مؤشر تقدم ويفقد المسودة والموقع غير قابل للتعديل	متوسطة	market_page.dart:348-366 orders_page.dart:94

العنوان	الخطورة	الدليل
أيام السبوت لايت تضيع بلا استرداد والإيقاف الإداري جزئي	متوسطة	server/market_plus.js:288,306-308,335-339,355
منتقي المواعيد بتوقيت الجهاز والخادم يتحقق بتوقيت الرياض	متوسطة	listing_page.dart:250 server/commerce.js:378-381
لا خطوة قبول/رفض صريحة للبائع؛ شارة «سريع الرد» تُشتق من أول تغيير مرحلة †	منخفضة	server/market_plus.js:40,47
قيمة مرحلة مجهولة تصبح delivered بصمت †	منخفضة	server/commerce.js:617
لا زر «مراسلة» للمشتري أو البائع في صفحة الطلب (صف المندوب فقط) †	منخفضة	orders_page.dart:236
بعد نجاح الطلب تبقى صفحة العرض بحالتها فتُعيد نقرة ثانية الطلب †	منخفضة	listing_page.dart:147-163
العرض يحمل bazaar_id واحداً: الانضمام لبازار ثانٍ يُسقطه من الأول بصمت †	منخفضة	server/market_b.js:35,124
حوار البازار الإداري يضبط startsAt=now دائماً فلا يمكن إنشاء بازار «قريباً» †	منخفضة	admin_market.dart:99
«أضف عروضك» يظهر للمشتري بلا عروض فتفتح ورقة فارغة †	منخفضة	bazaar_page.dart:291,325
bannerUrl يقبله الخادم ولا يُرسل أبداً †	منخفضة	server/market_b.js:140 admin_market.dart:99
انطباعات السبوت لايت تزيد مع كل جلب ل /market/home و /market/spotlight (بما فيه السحب للتحديث) لا لكل مشاهد فريد †	منخفضة	server/market_plus.js:289,356
حوار الكوبون بلا حقل انتهاء رغم دعم الخادم، وتبديله يرمي استثناءً غير معالج عند الفشل †	منخفضة	seller_tools.dart:96,112-116 server/market_plus.js:245-247

التطوير المقترح 1. تصفية الدفع الحقيقية: ورقة ملخص، تسليم إلى المحفظة عند نقص الرصيد، عنوان وهاتف للتوصيل، تأكيد للإلغاء، حالة «طلب» على صفحة العرض بعد النجاح (أثر عالٍ، أسبوع). 2. تحصين الدفع: عدّاد محاولات وقفل، قبول رمز البائع من on_the_way فصاعداً، إلغاء تلقائي للطلبات العالقة، حساب ضمان في الدفتر، شروط حالة في الاسترداد، قفل العرض داخل المعاملة، رفض قيم المراحل المجهولة (أثر عالٍ، أسبوع). 3. مركز نزاعات v2: سحب المشتري، رد البائع بصور، سجل أحداث، تدقيق، تقسيم صحيح للعمولة (أثر عالٍ، أسبوع). 4. حزمة تنظيمية: وسم أو تطهير البائعين الوهميين، تسمية المستند «إيصال طلب» حتى يحدد محاسب الفاتورة (أثر عالٍ، أسبوع). 5. تهيئة البائع: منتقي موقع، سعر أو «مجاناً» صريح، إعادة تقديم بعد الرفض، بقاء النموذج مع طبقة حفظ، خطوة قبول/رفض صريحة، زر مراسلة على صفحة الطلب (أثر متوسط، أسبوع). 6. المندوب كدور كامل بدعوة وقبول وأجر وتقييم (أثر متوسط، أسابيع). 7. البازارات: تعدد البازارات للعرض الواحد أو تحذير عند التبديل، startsAt قابل للاختيار، شعار البازار، إخفاء «أضف عروضك» لغير البائعين (أثر منخفض، أيام). 8. تحليلات صادقة: انطباعات لكل مشاهد فريد/جلسة، حقل انتهاء الكوبون ومعالجة أخطاء التبديل (أثر منخفض، أيام). 9. صفحات عامة للعروض بلا دخول (يعتمد على النواة) (أثر متوسط، أسابيع). 10. مزامنة docs/market.md مع الكود (أثر منخفض، أيام).

3.7 المحفظة والمدفوعات

الغرض. دفتر مغلق بالهلات (wallet_accounts/wallet_tx) تخصم منه كل ميزة مدفوعة. المال يدخل من الشحن التجريبي، أو قيد إداري، أو فاتورة ميسر المستضافة. لا سحب ولا استرداد للبطاقة.

خطوات المستخدم كما هي. الرئيسية ← المحفظة: رصيد بشارة «محمي بالرقم السري» (لا يوجد رقم سري في الكود)، نقاط، صف إجراءات (تحويل، دفع، تذاكري، حجوزاتي، عروضي، شحن، بالبطاقة). التحويل: حوار يُغلق ثم يُحل النك نيم ويُرسل فوراً بلا تأكيد للمستلم. البطاقة: POST /pay/topup يفتح فاتورة ميسر خارجياً، وبعد الدفع صفحة HTML ثابتة رابطها الوحيد إلى الجذر؛ الرصيد لا يتحدث حتى السحب للتحديث.

منطقية الخطوات وما ينقصها. تقنياً محكم، تنظيمياً وتشغيلياً غير جاهز: لا مفتاح إطفاء للتحويلات، لا فصل بين المال التجريبي والحقيقي، مساران إداريان يسگان رصيداً بلا تدقيق، لا معالجة لاستردادات ميسر أو الاعتراضات، لا مطابقة بين ميسر والدفتر، ثلاث نسخ من دالة الدفتر بسلوكيات مختلفة، والحساب الحي لدى ميسر غير مفعّل بعد.

نقاط القوة. التسوية لا تثق بالمتصفح؛ الفاتورة المستضافة تتجاوز قيد CSP وتدعم أبل باي؛ إدارة المفاتيح من اللوحة حذرة (السر لا يُعاد، كشف النسخ المقتّعة، فحص الاتصال)؛ القيد الإداري عبر `/adminapi/users/:id/credit` مسقّف ومدقّق.

المشكلات المؤكدة

العنوان	الخطورة	الدليل
الشحن التجريبي يسك مالا بنوع الحركة نفسه كمال البطاقة	عالية	<code>server/commerce.js:137-142</code> <code>server/market_b.js:394-396</code> <code>server/admin.js:139,145</code> (يمكن التمييز جزئياً بعمود ref)
استرداد السوق يُطبّق مرتين أو بعد الاكتمال	عالية	<code>server/commerce.js:646-647,659-664,687,693,700</code>
إلغاء الفعالية يفشل بخطأ خادم إن أنفق المضيف الإيراد	عالية	<code>server/commerce.js:103-111,252-253,299-307</code>
مساران إداريان لسك الرصيد بلا تدقيق	عالية	<code>server/commerce.js:137,145-152</code> مقابل <code>server/admin.js:356-370</code>
المحفظة تناقض المسار التنظيمي الموصى به	عالية	<code>server/commerce.js:155-169</code> <code>server/market_b.js:249</code> التقرير في <code>docs/reports</code>
استردادات المزود والاعتراضات لا تُعكس أبداً	عالية	<code>server/market_b.js:390-391</code>
رمز الجلسة الإداري في رابط CSV	متوسطة	<code>lib/pages/admin/admin_finance.dart:33-34</code> <code>server/admin.js:603-607</code>
أسرار البوابة نصاً صريحاً والويهوك بلا سر إلزامي	متوسطة	<code>server/market_b.js:45,275,427</code>
تعارض أفعال في التحويلات المتقابلة	متوسطة	<code>server/commerce.js:163-166,183</code>
ثلاث نسخ من الدفتر (اثنتان تسمحان بالسالب) ولا مطابقة ولا عرض للأرصدة السالبة	متوسطة	<code>commerce.js:103</code> (صارمة)؛ <code>admin.js:157-163</code> <code>business.js:228-234</code> (<code>allowNegative</code>)؛ <code>admin.js:594</code>
العميل يثبت سقف الشحن بدل قراءة الإعداد	متوسطة	<code>lib/api/commerce_models.dart:34</code> <code>wallet_page.dart:170,177,198</code>
التحويل بلا تأكيد للمستلم ولا حدود ولا ماسح وشارة PIN وهمية	متوسطة	<code>wallet_page.dart:48,113-139,146-151</code>
شحن البطاقة ينتهي في صفحة ثابتة بلا صفحة دفعات	متوسطة	<code>server/market_b.js:419-421</code> <code>wallet_page.dart:161-164</code>
لوحة المالية تغفل إيراد المنصة ودفعات البطاقة وتعرض الأنواع بالإنجليزية	متوسطة	<code>server/admin.js:589-591</code> <code>commerce_models.dart:68-71</code>
نص الحالة الفارغة يقول «رصيدك يُشحن عبر الإدارة حالياً» حتى مع تفعيل شحن البطاقة، وتُرس JoyCard فارغة تحته	منخفضة	<code>wallet_page.dart:72-73</code>

التطوير المقترح 1. مفاتيح الإطفاء التنظيمية قبل أي مفتاح حي: `transfersEnabled` و `chatPaymentsEnabled` مطفآن، رفض الشحن التجريبي مع مفاتيح حية، حد أدنى مئة ريال، سقف بطاقة منفصل (أثر عالٍ، أيام). 2. تحصين انتقالات الحالة المالية (شروط حالة، قفل مرتب، معالجة 40P01، النقاط نقص الرصيد في إلغاء الفعالية) مع حالات اختبار متزامنة (أثر عالٍ، أيام). 3. حجز إيراد التذاكر حتى الفعالية ومسار استرداد (أثر عالٍ، أسبوع). 4. إكمال دورة الدفع: حالة عدم تطابق، معالجة `refunded/voided/chargeback`، استرداد إداري للبطاقة، صفحة دفعات إدارية، مطابقة ليلية (أثر عالٍ، أسابيع). 5. وحدة دفتر واحدة مع `balance_after` ومفتاح تكرار ومطابقة ليلية (أثر متوسط، أسبوع). 6. حوكمة السك الإداري: حذف المسار القديم والتجاوز، سقف يومي، موافقة ثانية (أثر متوسط، أيام). 7. تجربة المحفظة: تأكيد المستلم، ماسح QR، قائمة دفعات،

عودة برابط عميق، ملصقات عربية، إزالة شارة PIN، إصلاح نص الحالة الفارغة (أثر متوسط، أسبوع). 8. الدفع لكل طلب عبر بوابة مرخصة بتقسيم للبائع، وإبقاء المحفظة للخدمات الداخلية فقط (أثر عالٍ، شهر فأكثر).

3.8 الدردشة والإشعارات والسلامة

الغرض. طبقة فوق نقل الرسائل في النواة تضيف الوسائط (رفع وتحويل ومصغرات)، الردود وإعادة التوجيه والتفاعلات، رموز ذكية تُحل إلى بطاقات (شخص، منفذ، #، /pay، /send، /split، /meet)، جدول إشعارات مع Web Push، وطبقة سلامة (كتم، كلمات محظورة، بلاغات بعثة إخفاء تلقائي، تصفية المحظورين، إخفاء منشورات الدوائر).

خطوات المستخدم كما هي. إرسال متفائل بفقاعة محلية وإعادة محاولة عند الفشل؛ الصور والصوت تُرفع عبر POST chat/upload ثم تُرسل كرابط نصي؛ /send ينفذ التحويل من العميل قبل إرسال الرسالة؛ /pay يسجل طلباً يدفعه الطرف الآخر من البطاقة؛ الكتم يخفي الشارة والصوت فقط؛ الحظر عبر النواة؛ البلاغ عن المحتوى يُخفي تلقائياً عند ثلاثة مبلّغين.

منطقية الخطوات وما ينقصها. الوسائط والبطاقات والإشعارات مبنية بعناية، لكن مسارات المال في الدردشة غير آمنة (send / يُصدّق بالمبلغ والوقت، /pay غير ذري، التحويل يسبق الرسالة)، بلاغات المحتوى بلا لوحة، المنشورات المخفية لا تُستعاد، الكتم لا يكتّم Push، ونحو عشرين نوع إشعار بلا وجهة. وموثوقية الإرسال نفسها هشة: لا مفتاح تكرار فمهلة 20 ثانية بعد أن خزنت النواة الرسالة تكرّرها عند إعادة المحاولة (client.dart:50)؛ الرسائل الفاشلة في الذاكرة فقط؛ load0lder يعطل الترقية نهائياً بعد خطأ عابر واحد (chat_thread_page.dart:403-405)؛ الفيديو يُشغّل بفتح الرابط خارجياً فقط؛ PDF يقبله الخادم ولا منتقي له في الواجهة.

نقاط القوة. البطاقات تحمل معرّفات فقط وتُحل من الخادم فلا يُزوّر سعر أو تذكرة؛ خط الوسائط يطبّع iPhone وAndroid إلى MP4 مع مصغرات؛ إشعارات Push بلا مكتبات خارجية مع تنظيف النقاط الميته؛ الإخفاء التلقائي يخطر المالك والإدارة برابط عميق؛ نحو ثلاثين اختبار ودجات وخمس حزم خادم.

المشكلات المؤكدة

العنوان	الخطورة	الدليل
/send «تم التحويل» يُدعى لعدة بطاقات بتحويل واحد	عالية	server/chat_cards.js:197-202 lib/api/commerce_api.dart:11 ref
/pay غير ذري: دفع مزدوج عند التزامن	متوسطة	server/chat_cards.js:219-238
/send ينقل المال قبل وجود الرسالة	متوسطة	chat_thread_page.dart:578-596,611-613
بلاغات المحتوى بلا لوحة إدارية	متوسطة	server/safety.js:36-40,173-179 server/admin.js:509-530
اكتشاف جدول البلاغات قد يربط content_reports	متوسطة	server/admin.js:36,62-64 server/notify.js:83-87
الإخفاء التلقائي قابل للتشديد بثلاثة حسابات	متوسطة	server/safety.js:61,158-171
مبلغ الطلب المسجل غير مرتبط بنص الرسالة	متوسطة	server/chat_cards.js:186-193 chat_cards.dart:264,269
فشل تسجيل الطلب يترك بطاقة ميته دائماً	متوسطة	chat_thread_page.dart:611-618,686-688,707-710
«كتم الإشعارات» لا يكتّم Push	متوسطة	server/safety.js:72 المستودع
نحو عشرين نوع إشعار بلا وجهة	متوسطة	lib/core/notify_open.dart:30-31,37-103
نقر Push والتطبيق مفتوح لا يفتح شيئاً	متوسطة	web/push_sw.js:17-23 hashchange (مذكور أيضاً في 3.1)
المنشورات المخفية في الدوائر لا تُستعاد من التطبيق	متوسطة	lib/api/naslife_api.dart:167 server/vessel_mod.js:139-151 بلا مستدعي؛

العنوان	الخطورة	الدليل
حذف الرسالة فوري بلا تأكيد والملف يبقى	متوسطة	chat_thread_page.dart:992, 1016-1034 مسار حذف في chat_tools.js
وسائط عامة دائمة بلا حصص	متوسطة	server/chat_tools.js:24-25, 28, 148, 184-185, 222
فلتر الكلمات المحظورة في العميل فقط للردشة وبمطابقة جزئية	متوسطة	chat_thread_page.dart:531-536 server/safety.js:17-27
رموز الدردشة المالية تحويلات P2P تحت السؤال التنظيمي	متوسطة	server/chat_cards.js:219-239 server/commerce.js:155-170
لا مفتاح تكرار للرسائل: مهلة 20 ثانية بعد تخزين النواة تكرار الرسالة عند إعادة المحاولة؛ الرسائل الفاشلة في الذاكرة فقط †	متوسطة	lib/api/client.dart:50 chat_thread_page.dart:761-806
_loadOlder يعطل الترتيم نهائياً بعد خطأ عابر واحد †	منخفضة	chat_thread_page.dart:403-405
الفيديو يُشغّل بفتح الرابط خارجياً فقط؛ PDF مقبول في الخادم بلا منتقي †	منخفضة	chat_thread_page.dart:1498-1501 server/chat_tools.js:33
«اقترح غيره» في بطاقة /meet يُدرج «/meet» فقط ولا يرفض الاقتراح الأصلي المعلق †	منخفضة	server/chat_cards.js:241-250

التطوير المقترح 1. جعل مال الدردشة من الخادم ومتكرر الأمان: التحويل داخل POST /chat/requests بـ ref=messageId، ادعاء الصف قبل التحويل في /pay، مفتاح فريد على wallet_tx(ref, kind) (أثر عالٍ، أسبوع). 2. لوحة إشراف لبلغات المحتوى والمنشورات المخفية مع تثبيت جدول البلاغات صراحة (أثر عالٍ، أسبوع). 3. تغطية كل أنواع الإشعارات مع اختبار يفشل عند نوع جديد ومعالجة hashchange (أثر عالٍ، أيام). 4. موثوقية الإرسال: إرسال localId كـ clientId إلى النواة لتقوم بـ upsert، صندوق صادر محفوظ (IndexedDB/shared_preferences) يصمد أمام إعادة التحميل، إزالة التكرار بالمعرف، إعادة محاولة الترتيم بعد الخطأ العابر، وملء الفجوة عند وصول أكثر من 50 رسالة أثناء الانقطاع (أثر عالٍ، أسابيع، يعتمد على النواة). 5. كتم حقيقي وإنفاذ الحظر في /chat/meta و /chat/react (أثر متوسط، أيام). 6. مكافحة التحشيد: حد بلاغات يومي، عمر حساب، عتبة أعلى للمحتوى المدفوع (أثر متوسط، أيام). 7. حصص وحذف وكنس للوسائط؛ مشغّل فيديو داخلي ومنتقي ملفات إن قصد دعم PDF؛ «اقترح غيره» يرفض الاقتراح الأصلي (أثر متوسط، أيام).

3.9 لوحة الإدارة ومساحة العمل

الغرض. مكتب خلفي: مؤشرات، إدارة مستخدمين، بلاغات، أنشطة ومطالبات، مالية، محتوى، إعدادات، تدقيق، فريق بأدوار وهيكل، مهام، صندوق بريد كامل لكل موظف (Resend/SMTP)، قواعد، قوالب، رضا العملاء، إرسال مجدول، ملخصات ذكية، إعداد مزود البريد والنطاق، والمدونة.

خطوات المستخدم كما هي. المدير يفتح /admin؛ الأقسام تُصقّى بالصلاحيات. معالجة بلاغ: تجاهل/تحذير/إيقاف بملاحظة. إدارة مستخدم: قيد رصيد، إيقاف، ترقية، حذف نهائي بكتابة الاسم. الفريق: إضافة عضو بدور وصندوق بريد. البريد: فتح الخيط يعلمه مقروءاً، الرد يُرسل من العنوان المستعار، الإغلاق يرسل بريد تقييم تلقائياً.

منطقية الخطوات وما ينقصها. كل الأقسام تعمل مع حزم اختبار كبيرة ونظام أدوار حقيقي. لكن الحذف النهائي يمحو الدفتر، إجراء البلاغ يوقف أي حساب من أي حامل reports.act، قسم السوق مكسور لغير المديرين القداماء، إلغاء المدير يُعاد عند كل إقلاع، الرابط العميق لبعض الإشعارات يفتح القسم الخطأ، وتقييم الرضا يُسجل عبر GET فتزوره مساحات الروابط. ومفتاح «الصيانة» في الإعدادات زينة: /settings/public يعيده لكن لا شيء في lib/ أو server/ يفرضه.

نقاط القوة. تفويض على مستويين يتدهور بلطف (server/team.js:21-84, 134-171)؛ كل إجراء إداري يكتب admin_audit ويخطر المتأثر؛ صندوق البريد مكتمل بشكل غير معتاد (ترابط بالرؤوس، تحقق Svix، قواعد، قوالب، ملاحظات داخلية، حضور، مسودات، صندوق صادر، رضا)؛ مساعد ذكي يعامل النص كبيانات؛ المدونة تُعرض من الخادم مع RSS وJSON-LD.

المشكلات المؤكدة

العنوان	الخطورة	الدليل
الحذف النهائي يسمح السجلات المالية والطلبات وإجراءات البلاغات بأسماء الأعمدة	عالية	server/admin.js:437-439,457,461-463,466 report_actions.admin_id NOT NULL (:30)
إجراء البلاغ يسمح لأي حامل reports.act بإيقاف أي حساب	عالية	server/admin.js:520-527 server/team.js:44-53,62-63
اسم صندوق بريد العضو غير فريد	عالية	server/team.js:95-98,232,278-280 server/inbox.js:122-126
إلغاء المدير المبدور يُعاد عند كل إعادة تشغيل	متوسطة	server/admin.js:95-97,101-124,496-497 server/admin_bootstrap.js:1-7
رمز الجلسة في رابط CSV والتصدير بصلاحيه finance.view فقط	متوسطة	server/admin.js:603-614 server/team.js:26,66
قسم السوق مرئي لكن مساراته للمديرين القدماء فقط	متوسطة	admin_shell.dart:32 server/market_plus.js:20,423-424 server/market_b.js:147
الرابط العميق يفتح قسم المالية بدل المحتوى	متوسطة	lib/core/notify_open.dart:96 admin_shell.dart:27-42
تنزيل مرفق البريد يمرر token= لا يقرؤه الحارس	متوسطة	admin_inbox.dart:556-559 server/inbox.js:802-806
تقييم الرضا يُسجل عبر GET	متوسطة	server/inbox.js:205,828-835
تعطيل مدير قديم في الفريق لا أثر له	متوسطة	server/team.js:137-138,272-277
إشعارات الإشراف لا تصل للفريق	متوسطة	server/notify.js:202-212
سجل التدقيق فيه ثغرات ولا يُصقّى	متوسطة	inbox.js لا استدعاء تدقيق في و tasks.js server/admin.js:690-695
القيد الإداري حتى مليون ريال بنقرة	متوسطة	server/admin.js:356-370
دليل المستخدمين لا يتجاوز أحدث خمسين	متوسطة	server/admin.js:322-333
وسم الإزعاج والتراجع يعملان عبر كل الصناديق	متوسطة	server/inbox.js:531-545
إزالة العضو تترك الخيوط والمهام والقواعد مرتبطة به	متوسطة	server/team.js:298-310
اكتشاف جدول البلاغات غير حتمي	متوسطة	server/admin.js:36,62
مفتاح «الصيانة» في settings/public لا يُنقذ في أي مكان (زينة)	متوسطة	server/admin.js:154 يعيده؛ لا مستهلك ل maintenance يمنع شيئاً في lib/ أو server/
GET /adminapi/settings يعيد webappDir/opsDir لكل حامل settings.view	منخفضة	server/admin.js:667
إضافة عضو للفريق بلا دعوة أو قبول: الوصول يبدأ لحظة حفظ المدير †	منخفضة	server/team.js:248-262
قائمة المدير المباشر تعرض الأعضاء الأعلى من الفاعل فيستطيع مشرف وضع عضو تحت المالك †	منخفضة	admin_team.dart (قائمة المدير غير مقيدة بالمستوى)
شاشة أول مدير غير قابلة للوصول عملياً (admin_bootstrap يبذر دائماً) ونصها يطلب SSH خلافاً لقاعدة «لا SSH»: setupHint و bootstrapFile يُعادان لغير الموثقين حين لا مدير، و POST /adminapi/setup بلا حد معدل †	منخفضة	server/admin.js:199-225 admin_shell.dart:220-282
«مهامي» تخفي المهام التي أنشأتها لغيري (تظهر تحت «فريقي» فقط) †	منخفضة	server/tasks.js:97 admin_tasks.dart:58

العنوان	الخطورة	الدليل
ورقة تعديل المهمة تعرض «بلا مسند» عندما يكون المُسند خارج القائمة المحمّلة †	منخفضة	admin_tasks.dart:336-338,250
تذكيرات المهام على مؤقت واحد داخل العملية بلا تعويض بعد التوقف؛ لا مهام متكررة ولا إعادة إسناد جماعي †	منخفضة	server/tasks.js:239
مسح حقل كلمة السر المقّتع ثم الحفظ يحو السر المخزّن †	منخفضة	admin_mail.dart:49,69 server/mail.js:365
GET /adminapi/mail/domain يستدعي واجهة المزود DNS عند كل تحميل للصفحة †	منخفضة	server/mail.js:419-423
بطاقة البريد تقول إن استعادة كلمة السر بالبريد غير متاحة رغم وجود † /auth/forgot	منخفضة	admin_mail.dart:198 docs/mail-setup.md:165-166
الرد في الصندوق بلا حقول To/CC مرئية (المستلم افتراضي بصمت)؛ إغلاق الخيط يرسل بريد CSAT تلقائياً بلا معاينة (askRating=false لا يمرّ أبداً)؛ فتح الخيط يعلمه مقروءاً حتى عند اطلاع مدير؛ لا حذف/دمج/إجراءات جماعية †	منخفضة	server/inbox.js:596,527,427
«حفظ ونشر» يكتب فوق المحتوى الحي بلا سجل نسخ؛ «نسخ الرابط» على مسودة ينسخ رابط 404؛ بلاطة «تدوينات جاهزة» في ماي سبيس مرئية لكل عضو فريق بينما الواجهة تحتاج blog.view :معاينة المسودات تعرض الترميز الخام †	منخفضة	server/blog.js:433-443 blog_drafts_page.dart:68 myspace_page.dart:99-100

التطوير المقترح 1. طبقة تفويض واحدة لكل /adminapi مع واجهة واعية بالصلاحيات (أثر عالٍ، أسبوع). 2. سياسة حذف تحتفظ بالسجلات المالية مجّهلة مع محاكاة قبل التأكيد ومنع الحذف عند رصيد غير صفري (أثر عالٍ، أسبوع). 3. سلامة صناديق البريد: فهرس فريد، أسماء محجوزة، إعادة إسناد عند المغادرة، دعوة/قبول للأعضاء، تقييد قائمة المدير بالمستوى (أثر عالٍ، أيام). 4. نموذج مديرين دائم يحترم الإلغاء، وإزالة شاشة الإعداد الأولى أو تصحيح نصها وحدّ معدل على /adminapi/setup (أثر عالٍ، أيام). 5. طابور إشراف موحد يجمع بلاغات المستخدمين والمحتوى مع إشعار الفريق (أثر عالٍ، أسبوع). 6. سجل تدقيق قابل للتحقيق وتسجيل الاطلاع على البيانات الشخصية (أثر متوسط، أيام). 7. ضوابط مالية: مطابقة، أرصدة سالبة، سقف قيد، تصدير آمن (أثر متوسط، أسبوع). 8. حزمة إصلاحات البريد: CSAT عبر POST، مرفقات موقعة، استرداد «جارٍ الإرسال» العالق، حراسة effort لنموذج To/CC، Haiku، تأكيد قبل CSAT، وضع «إطلاع» للمديرين، عدم محو السر عند مسح الحقل، تخزين نتيجة فحص النطاق (أثر متوسط، أيام). 9. تنفيذ مفتاح الصيانة فعلياً (لافتة ومنع الكتابات لغير المديرين) أو إزالته من الإعدادات (أثر منخفض، أيام). 10. المهام: «مهامي» تشمل ما أنشأته، تعويض التذكيرات بعد التوقف، مهام متكررة وإعادة إسناد جماعي (أثر منخفض، أيام). 11. المدونة: سجل نسخ مع استعادة، مفاتيح معاينة محفوظة، إعادة توجيه عند تغيير slug، معاينة مصيّرة في ماي سبيس وربط البلاطة بـ blog.manage (أثر منخفض، أيام).

3.10 البنية والتشغيل

تُفصّل في القسم السادس. الخلاصة هنا: خط النشر وتهيئة المخطط والتسوية والحزم موجودة ومعقولة، لكن سكربت النشر لا يحدّث الإضافات المنشورة، ولا نسخ احتياطي، واكتشاف الجداول بالتعبير النمطي يربط جداول خاطئة في الإنتاج (النمط نفسه في ست إضافات: safety.js و admin.js و notify.js للحظر والبلاغات، و search.js و vessel_mod.js و share.js لأعمدة users/vessels/profiles)، وعشر حزم من ثلاثين تفشل، ولا اختبارات في CI، والأسرار نصّاً صريحاً.

4. رحلات المستخدم حسب الشخصية

الدرجة من 0 إلى 3.

الشخصية	الدرجة (من 3)	أين تنكسر الرحلة
الزائر بلا حساب	1	جدار دخول كامل على الجذر؛ الوضع الضيفي فقط لروابط /c/ و /u/؛ روابط العروض /ل/ تهبط على شاشة الدخول؛ «مراسلة» تفتح شاشة مكسورة؛ لا عودة من شاشة الدخول إلى الصفحة المشاركة؛ لا سياسة خصوصية
المستخدم الجديد (أول عشر دقائق)	2	تسجيل بلا موافقة ولا سياسة؛ طلب موقع بلا سياق؛ لا تهيئة بعد الحوار الأول؛ بث فارغ محسوب حول جدة؛ عبارة الاسترداد تُرسل بالبريد؛ الحسابات القديمة بلا مسار استعادة
المشتري في السوق	2	الدفع من حوار «ملاحظة للبائع» بلا رصيد متبقي ولا عنوان ولا مسار شحن؛ ثلاثة مخارج متداخلة في paid؛ تجمد المال بلا مهلة بعد التحضير؛ استرداد مزدوج وبيع فوق المخزون؛ رمز تسليم يخمنه البائع
البائع الفرد	2	«المال في اليد» غير موجود (لا سحب، مؤجل تنظيمياً وغير معلن)؛ الرفض طريق مسدود؛ النشر يفقد المسودة ويثبت موقع الجهاز؛ الإيراد المعروض حجوزات لا مدفوعات
صاحب الدائرة التجارية	2.5	المال يُقيد فوراً ثم يُخصم من مالك اللحظة؛ البذر يعيد المخزون والحالة؛ المحرر لا يختار النوع؛ التقييم بلا شراء؛ المطالبة بلا دليل؛ أعضاء بلا إشعارات لأن near غير منقذ
المندوب	1	يُعين بلا موافقة ويرى بيانات المشتري؛ لا مراسلة؛ لا أجر؛ لا تقييم؛ يُلغى تكليفه في أي حالة؛ يقفز من paid إلى on_the_way
منظم الفعالية ومشتري التذاكر	1.5	المكان هو موقع المنظم؛ فئة واحدة؛ لا تعديل؛ إلغاء بنقرة قد يفشل بخطأ خادم عندما أنفق الإيراد فلا يُسترد لأحد؛ لا استرداد أو نقل للمشتري
المشرف والفريق	2.5	إجراء البلاغ يوقف أي حساب؛ الحذف يسمح الدفتر؛ لا واجهة لبلاغات المحتوى ولا لاستعادة المخفي؛ قسم السوق خطأ 403 للفريق؛ اكتشاف الجداول قد يعطل الحظر بصمت؛ النشر التلقائي قد لا يوصل الإصلاحات

5. أهلية الخدمات للإطلاق الآن

الدرجة من 0 إلى 3 (0 = يجب إخفاؤه الآن، 3 = صالح للإطلاق بإصلاحات صغيرة).

الخدمة	الدرجة (من 3)	ما يجب إخفاؤه أو تقييده حتى الإصلاح
الحسابات والدخول والملف	3	إضافة سياسة الخصوصية والشروط وحذف ذاتي وشاشة استعادة بالعبارة (أيام)؛ عدم إرسال العبارة بالبريد
القشرة والرئيسية والبحث والإشعارات	3	احترام «ملف خاص» والحظر في البحث؛ إلغاء Push عند الخروج؛ إصلاح رابط /1/
الخريطة والمنشئ والبحث	2.5	إصلاح فقدان الصوت ورفض الروابط الخارجية وواجهة حجب/استعادة وتعقيم الموقع
الدوائر التجارية	1	تصفح ومطالبة فقط؛ منع الشراء والحجز على كل دائرة بلا مالك (مستشفيات، سينمات، فنادق، مطاعم)؛ تصبح 3 بعد إصلاح المال
الدوائر المجتمعية ومساحات المجتمع	3	صالحة مع لوحة إشراف للمخفي
الفعاليات والتذاكر	1.5	الفعاليات المجانية فقط؛ تعطيل التسعير حتى حجز الأموال والاسترداد
العروض والأمنيات والبحوث المحفوظة	2	إخفاء إهداء الكوبونات ونقاط الولاء؛ جعل الافتراضي <code>all</code> : معاينة قبل الدفع
السوق	1.5	تصفح ومراسلة فقط حتى إصلاح رمز التسليم والاسترداد المكرر والبائعين الوهميين؛ تصبح 3 بعدها
المحفظة والدفع	0.5	إطفاء الشحن التجريبي، إخفاء «تحويل/دفع»، إبقاء البطاقة مغلقة حتى قرار المسار المرخص ورفع الحد الأدنى وخفض الأقصى
الدردشة	2.5	إطفاء <code>pay</code> و <code>send</code> و <code>split</code> / خلف إعداد منصة؛ الباقي جاهز
السلامة والإشراف	1.5	تثبيت جدول الحظر والبلاغات صراحة؛ إصلاح إجراء البلاغ؛ لوحة بلاغات المحتوى قبل أي إطلاق عام
لوحة الإدارة ومساحة العمل	3	للاستخدام الداخلي؛ إصلاح الحذف وإجراء البلاغ وحراسة السوق؛ المدونة جاهزة للنشر العام
البنية والنشر	1.5	إصلاح <code>autodeploy.sh</code> والنسخ الاحتياطي قبل أي شيء آخر (أيام)

6. البنية التقنية والمخاطر التشغيلية

أرقام لتقدير حجم العمل. الخادم 26 إضافة Fastify (نحو 10,500 سطر) تُحقن في نواة خارج المستودع. الاقتتان عبر 187 إشارة إلى `globalThis.naslife*` (48 تعريفاً في 18 ملفاً). المخطط: 88 عبارة `CREATE TABLE IF NOT EXISTS` مع 4 مفاتيح REFERENCES فقط، و43 سطر `ADD COLUMN IF NOT EXISTS`، و14 استعمال `information_schema` موزعة على 12 إضافة. معالجة الأخطاء: 29 موضع `catch(() => {})`، و `app.log` مستخدم في 5 إلى 10 إضافات فقط من 32 ملفاً (المحققون اختلفوا في العدّ حسب المعيار). الاختبارات: 30 حزمة خادم و177 اختبار `testWidgets` في 40 ملفاً.

النواة خارج المستودع. المصادقة والمستخدمون ونقل الرسائل والمقبس واشتراكات Push و `health/` وتقديم الملفات الثابتة تعيش فقط في `/opt/naslife/src`. المستودع يرقع `index.js` هناك بـ `sed` (59-47 `server/autodeploy.sh`)، ولا يحوي `server/index.js` ولا `server/package.json`، و12 إضافة تستكشف مخطط النواة عند الإقلاع عبر `information_schema`. خادم مفقود أو `index.js` تالف لا يمكن إعادة بنائه من `git`.

النشر. `server/autodeploy.sh:35` يسمح `ops/rollback/*` في بداية كل نشر كود، بينما 41: يتخطى أي ملف موجود في `src` بلا علامة `absent`. تُكتب فقط في 43: عند أول نشر داخل المجلد الممسوح نفسه. النتيجة: في نسخة المستودع لا يمكن لأي إضافة أن تُحدّث بعد نشرها الأول، والتخطي يُسجّل تحذيراً في سجل لا تراه الجلسة. الأدلة على أن الإنتاج يشغّل نسخة أقدم: `server/business.js:146-149` يوتّق جسر المنفذ 3000 لسكربت مثبتّ أقدم، وزمن التشغيل الحي (`uptimeSec` 411963 في 24 سبتمبر) يوافق إعادة تشغيل بعد آخر التزام على `market_b.js` بدقة. أي تشغيل لـ `install-autodeploy.sh` (خطوة Actions عند وجود السر، أو الأمر الموثّق) يثبّت النسخة المعطوبة. كل نشر يعيد تشغيل العملية الوحيدة فيُسقط المقابس والويهوكات لثوانٍ. الدفع إلى الفرع يعني `root` على الخادم عبر Actions (`github/workflows/deploy.yml:106-109`) وصلاحيّة مدير عبر `admin_bootstrap.js` الذي يُعاد إدراجه عند كل إقلاع.

اكتشاف الجداول. `server/safety.js:42,47` يختار أول جدول يطابق `/block/` من استعمال بلا ترتيب، و `server/inbox.js:75` ينشئ `inbox_blocked` الذي يطابق النمط؛ الفحص الحي لـ `safety/status/` في 24 سبتمبر أعاد `blocks:false`، وحزمة `harness_safety` تعيد إنتاجه، فالحظر بين المستخدمين معطل فعلياً في تصفية منشورات الخريطة والمجتمع. النمط نفسه في `admin.js:62` و `notify.js:86` لجدول البلاغات، و `/notify/status/` الحي يُظهر `content_reports`، فبلاغات المستخدمين من النواة لا تصل الإدارة. والاكتشاف بالتعبير النمطي ذاته يُستخدم أيضاً في `search.js` و `vessel_mod.js` و `share.js` لأعمدة `users/vessels/profiles`، فإصلاح «تثبيت أسماء الجداول» يجب أن يغطي الإضافات الست لا الثلاث.

النسخ الاحتياطي. لا `pg_dump` ولا `rsync` في أي سكربت أو توثيق؛ النسخ الوحيد هو نسخة `Caddyfile` (`server/restore-caddy.sh:31,64`). قاعدة البيانات والوسائط و `Caddy` و `Node` كلها على خادم واحد. مجلد الوسائط قد يسقط إلى `os.tmpdir()` بصمت (`server/chat_tools.js:23-25`)، وكاش البلاطات ينمو بلا حد. (وجود لقطة من مزوّد الاستضافة لا يمكن التحقق منه من المستودع؛ انظر قائمة المالك أدناه).

نموذج البيانات. لا نظام ترحيلات؛ `wallet_accounts/wallet_tx` مُعرّفان ثلاث مرات (`commerce.js:18-22`)، `ledger()` بقواعد مختلفة: **اثنتان تسمحان بالسالب** (`admin.js:31-32`، `business.js:75-79`) وثلاث دوال (`admin.js:157-163` و `business.js:228-234` بخيار `allowNegative`) وواحدة فقط صارمة (`commerce.js:103`). أربعة مفاتيح أجنبية فقط في 88 جدولاً. تحديثات على جداول كاملة عند كل إقلاع (`commerce.js:49-50,56,77`). حذف المستخدم الإداري يمر على كل الجداول ويحذف كل صف يحمل `user_id/buyer_id/seller_id` بما فيها الدفتر والدفوعات والطلبات والتذاكر (`server/admin.js:437-467`).

الاختبارات. إعادة تشغيل `server/test/run.sh all` في هذه الجلسة (24 سبتمبر): **عشر حزم من ثلاثين تفشل**: `harness`، `admin_bootstrap`، `admin`، `chat_tools`، `community`، `hospital`، `notify`، `owner`، `safety`، `share`؛ بينما `CLAUDE.md` يذكر `harness_admin` فقط. الأسباب متميزة ويجب ألا تُخلط: - **ملفات ناقصة من المستودع**: `chat_tools` (`server/test/media/test.png`) و `admin_bootstrap` (`ops_boot/admin-setup-code`). - **تلوث قاعدة الاختبار بين الحزم** (`run.sh:9-13`): `harness_admin` يسقط جدول `profiles` ويعيد إنشائه بأعمدة مختلفة

فتفشل harness_share بخطأ profiles.user_id : community ؛ تعدّ 12 مقهى بدل 10؛ owner تعيد already-owned وتسقط بـ myRole TypeError . - بيئة: admin تحتاج مجلد webapp، و chat_tools تحتاج ffmpeg . - أخطاء حقيقية في الكود: safety تربط inbox_blocked كجدول حظر، و notify تربط content_reports كجدول بلاغات.

53:github/workflows/deploy.yml. يشغّل flutter analyze فقط ثم يدفع الحزمة؛ لا flutter test ولا حزم الخادم. اختبارات الودجات: العدّ الفعلي 177 testWidgets في 40 ملفاً، بينما CLAUDE.md يقول «نحو 230»؛ التقرير لم يجد مصدراً للرقم الثاني ويُرجّح أنه قديم أو يعدّ اختبارات test() غير الودجية. الشاشات الأثقل (الخريطة، الطلبات، نموذج العرض، صفحات المنشئ، مالية وسوق وبلاغات الإدارة) بلا اختبار وودجات، و tiles.js بلا حزمة. لا بيئة staging؛ التطوير المحلي يوجّه إلى الإنتاج (lib/api/client.dart:74-76) وسكربتات التحقق تستخدم رمز جلسة المؤسس.

المراقبة. لا setErrorHandler ولا unhandledRejection؛ الكنس الدوري يبتلع أخطاءه (map_posts.js:407)، inbox.js:848، wishlist.js:195، saved_search.js:101، tasks.js:239؛ 29 موضع ({} => catch())؛ فحص الصحة في النشر يقبل أي رد ناجح حتى لو عُطّلت إضافة. لا مراقب توفر ولا مطابقة للدتر.

الأداء. استعلام مستخدم لكل صف في القوائم (business.js:813-815، commerce.js:336، 519-521، 529)، لا فهرس على market_orders(buyer_id/seller_id) ولا market_listings(seller_id)؛ بحث 'ILIKE %q%' بلا pg_trgm؛ ست مؤقتات استطلاع في العميل بلا إيقاف عند إخفاء التبويب؛ حزمة الويب ثقيلة (main.dart.js) نحو ستة ميغابايت مع wasm بين ثلاثة ونصف وسبعة؛ تُعاد كاملة بعد كل إصدار لأن index.html:52-59 يحذف كل الكاش ولا deferred as في lib/، وملفات symbols. تُنشر.

الوسائط. POST /chat/upload بلا حصة ولا حد معدل (chat_tools.js:184) و ffmpeg متزامن داخل الطلب بمهلة تصل دقيقتين ونصف؛ لا كنس للملفات اليتيمة.

الاقتران. 187 إشارة إلى globalThis.naslife* تربط الإضافات بترتيب register.txt، مع جيل تعويضية (جسر المنفذ 3000، تعديل process.env.WALLET_TEST_TOPUP وقت التشغيل في admin.js:145).

ما لا يستطيع فعله إلا المالك على الخادم الآن (P0، قبل أي شيء آخر): 1. مقارنة السكريبت المثبت بنسخة المستودع: cat /opt/naslife/ops/autodeploy.sh ومطابقته مع server/autodeploy.sh (هل يحوي سطر rm -f ops/rollback/* قبل فحص absent.؟). 2. grep 'not managed' /opt/naslife/ops/autodeploy.log - أي نتيجة تعني أن إضافات تُتخطى. 3. md5sum /opt/naslife/src/*.js ومقارنتها بملفات الفرع server/*.js لمعرفة الإضافات التي لم تصل. 4. curl -sS https://naslife.app/notify/status و curl -sS https://naslife.app/safety/status وتسجيل blocksTable و reports.table بعد كل إعادة تشغيل. 5. التأكد هل لدى مزوّد الاستضافة لقطة (snapshot) أو نسخ احتياطي للقرص؛ إن لم يكن، تشغيل pg_dump -Fc يدوي فوراً قبل أي تغيير. 6. التأكد من أن /opt/naslife/ops/auth-key (مفتاح تشفير عبارات الاسترداد) منسوخ خارج الخادم؛ فقدانه يعطل الاستعادة بالبريد وتغيير كلمة السر لكل الحسابات. (تذكير من CLAUDE.md: أوامر SSH من PowerShell تُكتب بعلامات اقتباس مفردة وبلا \$).

6.1 بطاقة البنية التقنية (من 10)

المحور	الدرجة	المبرر
خط النشر (autodeploy، CI) نشر الحزمة	3	التراجع وفحص الصحة موجودان، لكن نسخة المستودع لا تحدّث الإضافات المنشورة، والإنتاج يشغّل نسخة منحرفة، وكل نشر يقطع الاتصالات، و CI بلا اختبارات، وكاتبان لفرع الحزمة
الاعتماد على النواة والتعافي من الكوارث	2	النواة خارج المستودع، index.js يُرَقع بـ sed، المخطط يُستنتج بالتعبير النمطي (ربطان خاطئان في الإنتاج اليوم). لا نسخ احتياطي، خادم واحد
نموذج البيانات وتطوّر المخطط	4	التهيئة الذاتية مريحة، لكن لا ترحيلات، جداول ودفاتر مكررة، 4 مفاتيح أجنبية في 88 جدولاً، تحديثات إقلاع، حذف بأسماء الأعمدة
صحة مسارات المال	4	معاملات وأقفال وتسوية متكررة الأمان موجودة، لكن البيع الزائد والاسترداد المزدوج وتعارض الأقفال مؤكدة في الكود، و wallet_tx بلا مفتاح تكرار

المحور	الدرجة	المبرر
تغطية الاختبارات	5	30 حزمة و177 اختبار ودجات حقيقية، لكن 10 من 30 تفشل، لا شيء في CI، والخريطة والطلبات ونموذج العرض والمنشئ والمالية بلا اختبار
المراقبة والتنبيه	2	29 موضع ابتلاع، لا معالج مركزي، log، app في قلة من الإضافات، health / سطحي، لا مراقب توفر ولا مطابقة، السجلات غير مقروءة من الجلسات
أداء الخادم	5	مقبول اليوم؛ N+1 على المستخدمين وفهارس ناقصة للطلبات والعروض وبحث ILIKE بلا فهرس يتدرج خطياً
أداء العميل (الويب)	4	6.1 م.ب main.dart.js + 3.6-7.3 م.ب wasm تُعاد كل إصدار، لا deferred، ست مؤقتات بلا حراسة رؤية
الوضع الأمني للبنية	5	CSP صارم، عبارات مشفرة، مقارنة وبيهوك ثابتة الزمن، تدقيق؛ يقابلها أسرار نصية، رموز في URL، root من فرع النشر، منح مديرين عند الإقلاع، تشخيص عام
جودة الكود والافتتان	5	إضافات مقروءة ودفاعية يربط عربي متسق للأخطاء، لكن 187 إشارة globalThis، اعتماد على الترتيب، جيل تعويضية، ثلاث نسخ دفتر

الأولويات التقنية. (أ) إصلاح سجل الملفات المُدارة في النشر وتحويل التخطي إلى فشل مُخطر، والتحقق فوراً على الخادم (القائمة أعلاه). (ب) تثبيت أسماء جداول النواة صراحة بدل التعبير النمطي في الإضافات الست مع تأكيد الأعمدة عند الإقلاع. (ج) pg_dump ليلي خارج الخادم مع rsync للوسائط وتمرين استعادة. (د) تصحيح سباقات المال. (هـ) استبدال الحذف الإداري بحذف ناعم يحفظ السجلات المالية. ثم: تخضير الحزم (إعادة ضبط القاعدة لكل حزمة، إيداع الملفات الناقصة، تخطّ عند غياب ffmpeg) ووظيفة اختبار في CI، معالج أخطاء مركزي و health / عميق ومراقب توفر، تشفير الأسرار، staging، schema_migrations ووحدة دفتر واحدة، وفهارس وتجميع استعلامات، تقسيم الحزمة وكاش الأصول.

7. الأمن ومكافحة الإساءة (المؤكد فقط)

ما يصمد. لا حقن SQL (كل الاستعلامات مُعلّمة والأجزاء المدمجة معرّفات أو أرقام مقيدة)؛ لا XSS في صفحات HTML التي يولدها الخادم (market_b.js ,blog.js ,share.js ,market_plus.js فاتورة market_plus.js تهرب كل المدخلات)؛ CSRF غير وارد لأن الرمز يُرسل في ترويسة x-token لا في كوكي؛ CSP صارم من Caddy (script-src 'self')؛ عبارة الاسترداد مشفرة بمفتاح خارج المستودع؛ مقارنة سر الويبيوك بزمان ثابت؛ سجل تدقيق لأغلب الإجراءات الإدارية.

7.1 بطاقة الأمن (من 10)

المجال	الدرجة	المبرر
المصادقة والجلسات (auth_alias.js + العميل)	6	العبارة مشفرة AES-GCM والاكواد مجزأة بحدود محاولات، لكن احتلال البريد، وإرسال العبارة بالبريد، وتعداد الحسابات، ومحدّد الدخول في الذاكرة لكل IP فقط، وغياب معالجة 401 أثناء الاستخدام، ورمز الجلسة في URL الفاتورة
صلاحيات الإدارة والفريق (admin.js + team.js)	5	RBAC حقيقي وتدقيق لمعظم الإجراءات، لكن reports.act يوقف أي حساب، الحذف النهائي يمحو الدفتر، قائمة المديرين في المستودع تعيد المنح بعد السحب، بيانات المستخدم الكاملة لكل users.view بلا تسجيل وصول، وسك رصيد غير مدقق
المحفظة والدفتر والدفع (market_b.js + commerce.js)	4	القيود داخل معاملات مع FOR UPDATE وتسوية ميسر idempotent، لكن الشحن التجريبي غير مميّز، التحويلات بلا حدود، deadlock محتمل، الأسرار نصّ صريح، ولا حساب ضمان
سوق المستخدمين (commerce.js + market_plus.js)	3	رمز التسليم قابل للتخمين ويُقبل قبل التسليم، استرداد مزدوج، بيع زائد، تعيين مندوب بلا موافقة، بائعون وهميون في الإنتاج
الدوائر التجارية والعروض (offers.js + business.js)	5	guard() موحد ومعاملات مقفلة على الأصناف، لكن الدفع لدوائر بلا مالك، الاسترداد من المالك الحالي، تقييم مفتوح للجميع، وتحويل كوبونات غير ذري
الدرشة والإشعارات والإشراف (chat_tools/chat_cards/notify/safety)	5	البطاقات تُحلّ من الخادم و Web Push بلا مكتبات، لكن /send /يُزوّر بالمبلغ والوقت، /pay غير ذري، اكتشاف جدول الحظر قد يعطله، الإخفاء التلقائي قابل للتشديد، وميتا الرسائل بلا فحص طرفين
الرفع والوسائط (chat_tools.js + tiles.js)	5	أسماء غير قابلة للتخمين وأنواع محصورة، لكن بلا حصة ولا حدّ معدّل ولا فحص بايتات، ffmpeg مترامن، ملفات عامة دائمة بلا حذف، سقوط صامت إلى tmpdir
صفحات HTML من الخادم (blog.js ,share.js ,market_b.js ,CSAT)	8	تهريب كامل للمدخلات، روابط محصورة، CSP صارم؛ لا XSS مكتشف. الملاحظات: CSAT عبر GET، وتسريب webappDir في /share/status
النشر والأسرار والبنية (autodeploy, deploy.yml, bootstrap)	4	لا أسرار في المستودع والعبارة مشفرة بمفتاح خارجه، لكن الدفع إلى الفرع يمنح الإدارة والجذر، الأسرار الحية نصّ صريح في القاعدة، ونقاط تشخيص عامة

الثغرات المؤكدة حسب الفئة

الفئة	المشكلة	الدليل
مسارات المال	رمز التسليم من أربعة أرقام بلا عدّاد ويُقبل في paid	server/commerce.js:586,638-640
مسارات المال	استرداد مزدوج وبيع فوق المخزون وتعارض أقفال	server/commerce.js:646,663,564,592-593,163-166
مسارات المال	سك رصيد بلا تدقيق (شحن تجريبي، تجاوز المدير، مسار قديم)	server/commerce.js:137-152
مسارات المال	/send /يُزوّر بالمبلغ والوقت و /pay غير ذري	server/chat_cards.js:197-202,219-238
مسارات المال	إهداء الكوبون غير ذري وسقوط بلا قفل	server/offers.js:303-314,101-120
الصلاحيات	أي حامل reports.act يوقف أي حساب	server/admin.js:520-525 server/team.js:44-51,64-65

الفئة	المشكلة	الدليل
الصلاحيات	تعيين مندوب بلا موافقة يكشف بيانات المشتري	: server/market_b.js:76-82 server/commerce.js:517-521
الصلاحيات	بيانات المستخدم الكاملة لكل حامل users.view بلا تسجيل وصول	server/admin.js:284-318,337-353
الصلاحيات	صندوق بريد العضو غير فريد فيُعرض بريد زميل	server/team.js:95-98,232,278-281
الجلسات	رمز الجلسة في عناوين URL (الفاتورة و CSV)	: server/market_plus.js:400 server/admin.js:605-606
الجلسات	الخروج لا يلغي اشتراك Push	lib/state/app_state.dart:169-174
المصادقة	احتلال البريد غير المؤكد؛ تغيير البريد بلا إعادة توثيق؛ تعداد الحسابات عبر /auth/forgot ؛ محدد الدخول في الذاكرة لكل IP فقط	server/auth_alias.js:85,175,197-201,211-225,314-333,54-63,196
المصادقة	العبارة السرية تُرسل بالبريد	server/auth_alias.js:115-131
الإشراف	اكتشاف جدول الحظر قد يعطل الحظر بصمت (مؤكد حياً)	server/safety.js:42,47-51
الإشراف	الإخفاء التلقائي قابل للتشديد بثلاثة حسابات جديدة	server/safety.js:61,158-171
الإشراف	تقييم بلا شراء وإعادة التقييم تسمح رد المالك	server/business.js:517-528
الإشراف	فلتر الكلمات المحظورة للدردشة في العميل فقط وبمطابقة جزئية	: server/safety.js:17-27 chat_thread_page.dart:531-536
البيانات الشخصية	بحث الأشخاص بلا دخول ويكشف النبذة ويتجاهل is_public والحظر	server/search.js:64,70-79
البيانات الشخصية	الحذف النهائي يمحو الدفتر وإجراءات البلاغات	server/admin.js:437-467
الأسرار	مفاتيح ميسر والبريد و Anthropic نصاً صريحاً في القاعدة؛ بحث «سحري» عن مفتاح VAPID في أي جدول أو ملف	: server/market_b.js:275 : server/mail.js:365-368 : server/inbox.js:91,865 server/notify.js:118-136
النشر	الدفع إلى الفرع يمنح root ومديراً؛ الإلغاء لا يصمد أمام إعادة التشغيل	: .github/workflows/deploy.yml:100-109 server/admin.js:117-124,496-497
المدخلات	روابط خارجية مقبولة لوسائط المنشورات وشعارات الدوائر	: server/map_posts.js:103-109 server/business.js:392-396,555
الرفع	بلا حصة ولا حد معدل، نوع من الترويسة فقط، ملفات عامة دائمة	server/chat_tools.js:184-191,148,222
الكشف	نقاط /status عامة تكشف أسماء الجداول والمسارات وأخطاء الدفع؛ GET /adminapi/settings يعيد webappDir/opsDir لكل حامل settings.view ؛ setupHint و bootstrapFile لغير الموثقين حين لا مدير	: server/notify.js:242-245 : server/share.js:108 : server/auth_alias.js:363-368 : server/profile.js:27 server/admin.js:667,199-208
IDOR	ميتا الرسائل وتفاعلاتها لأي معرف؛ أحداث المنشورات بلا فحص وجود	: server/chat_tools.js:247-286 server/map_posts.js:294-302
CSRF	تقييم الرضا يُسجل عبر GET	server/inbox.js:205,832-835

ما يعتمد على النواة ولا يمكن التحقق منه هنا: انتهاء الجلسات، حد محاولات الدخول الفعلي، إنفاذ الحظر في نقل الرسائل، منع الرسائل للموقوفين، اشتراكات Push، سياسة القراءة بلا جلسة للروابط الضيفية.

8. خارطة طريق مقترحة

الآن (أسبوعان)

البند	الأثر	الجهد	يعتمد على
إصلاح <code>autodeploy.sh</code> (سجل ملفات مُدارة لا يُمسح، التخطي فشل مُخطر، بصمة نشر في <code>verify_live.sh</code>) والتحقق على الخادم	عالٍ	أيام	المالك بفحص السجل (قائمة القسم 6)
نسخ احتياطي ليلي <code>rsync + pg_dump</code> للوسائط خارج الخادم مع تمرين استعادة	عالٍ	أيام	تخزين خارجي
تثبيت أسماء جداول النواة صراحة في الإضافات الست واستثناء جداول المستودع وتسجيل الجدول المختار	عالٍ	أيام	لا شيء
حزمة سلامة المال: منع الطلب على الدوائر بلا مالك، عداد رمز التسليم وربطه بالحالة، شروط حالة في الاسترداد، قفل العرض داخل المعاملة، قفل مرتب في التحويل، التقاط نقص الرصيد في إلغاء الفعالية	عالٍ	أيام	لا شيء
مفاتيح الإطفاء التنظيمية: <code>transfersEnabled</code> و <code>chatPaymentsEnabled</code> مطفآن، رفض الشحن التجريبي مع مفاتيح حية، نوع <code>test_topup</code> ، حد أدنى مئة ريال، سقف بطاقة منفصل، حذف مساري السك غير المدققين	عالٍ	أيام	قرار المالك
حذف ناعم يحفظ السجلات المالية ويمنع الحذف عند رصيد غير صفري	عالٍ	أيام	لا شيء
إصلاح إجراء البلاغ (الهدف من صف البلاغ واشتراط <code>users.manage</code>) وفهرس فريد لصناديق البريد	عالٍ	أيام	لا شيء
سياسة الخصوصية والشروط وسطر الموافقة وحذف ذاتي بإعادة توثيق	عالٍ	أيام	صياغة قانونية
وسم أو تطهير البائعين الوهميين وحراسة البذر بمتغير بيئية: عدم لمس <code>active/stock</code> في بذر الدوائر	متوسط	أيام	لا شيء
إصلاح رابط <code>/l/</code> وشاشة استعادة بالعبرة وإلغاء <code>Push</code> عند الخروج	عالٍ	أيام	لا شيء

التالي (شهر إلى شهرين)

البند	الأثر	الجهد	يعتمد على
تخضير حزم الخادم (إعادة ضبط القاعدة لكل حزمة، إيداع الملفات الناقصة، تخطُّ عند غياب <code>ffmpeg</code>) ووظيفة اختبار في CI تمنع دفع الحزمة	عالٍ	أسبوع	لا شيء
معالج أخطاء مركزي، <code>/health</code> عميق، مراقب توفر، مطابقة ليلية للدقتر، تشفير الأسرار بمفتاح <code>ops/auth-key</code>	عالٍ	أيام	لا شيء
تصفية دفع حقيقية في السوق (ملخص، رصيد، عنوان توصيل، تأكيد) ومركز نزاعات بجانبين وتدقيق	عالٍ	أسبوعان	حزمة سلامة المال
حجز أموال الدوائر حتى الاستلام مع <code>credited_to</code> وتبويب تسويات للمالك؛ حجز إيراد التذاكر واسترداد للمشتري	عالٍ	أسبوعان	حزمة سلامة المال
مال الدردشة من الخادم (<code>/send</code> داخل <code>POST /chat/requests</code> بـ <code>ref</code> ، ادعاء قبل <code>/pay</code>)	عالٍ	أسبوع	مفاتيح الإطفاء
لوحة إشراف موحدة (بلاغات المستخدمين والمحتوى، استعادة المنشورات، إشعار الفريق، مكافحة التحشيد)	عالٍ	أسبوع	تثبيت الجداول
تهيئة أول تشغيل (مدينة، شرح الموقع، دوائر مقترحة، صورة، إشعارات) وتطبيق المسرد الموحد	عالٍ	أسبوع	لا شيء
تغطية كل أنواع الإشعارات مع اختبار، <code>hashchange</code> لنقر <code>Push</code> ، تقييم وحذف في صفحة الإشعارات	متوسط	أيام	لا شيء
معاينة العرض قبل الدفع، الافتراضي <code>all</code> ، معاملة حقيقية للإهداء، فهرس <code>pg_trgm</code> وحد أدنى حرفين للبحث	متوسط	أسبوع	لا شيء
طبقة تفويض واحدة لكل <code>/adminapi</code> وواجهة واعية بالصلاحيات ونموذج مديرين يحترم الإلغاء	متوسط	أسبوع	لا شيء
إصلاحات المنشئ (الصوت عند التعديل، حد النص، الفيديو إلى السوق، الروابط الخارجية، تعقيم الموقع) وقسم إداري للمحتوى المكاني	متوسط	أسبوع	لا شيء
بيئة <code>staging</code> بقاعدة ومنفذ مستقلين وحساب تحقق غير إداري	متوسط	أسبوع	الخادم

لاحقاً (ربع سنة)

البند	الأثر	الجهد	يعتمد على
الدفع لكل طلب عبر بوابة مرخصة بتقسيم للبائع (Tap Marketplace أو ميسر Platforms) وإبقاء المحفظة داخلية	عالي	شهر فأكثر	قرار المالك، تفعيل حساب ميسر، محاسب
توجيه URL كامل (go_router) وتصفح عام بلا حساب للرئيسية والخريطة والبحث وصفحات عامة للعروض	عالي	أسابيع	سياسة القراءة بلا جلسة في النواة
إعادة تنظيم المعلومات (القسم 8.4)	عالي	أسابيع	المسرد
إدخال النواة إلى المستودع (أو نسخة للقراءة وعقد API موثّق) وملف تسجيل واحد بدل حقن sed ، و schema_migrations ، ووحدة دفتر واحدة، ومفاتيح أجنبية لجداول المال	عالي	أسابيع	وصول المالك للخادم
موثوقية الإرسال في الدردشة (معرف عميل في النواة، صندوق صادر محفوظ) وكتم يشمل Push	متوسط	أسابيع	النواة
المندوب كدور كامل، تحويل طلبات المشترين إلى طلبات بضمن، الفعاليات v2	متوسط	أسابيع	السوق المحصّن
أداء: تجميع المستخدمين، فهارس الطلبات والعروض، إيقاف المؤقتات عند الإخفاء، تقسيم الحزمة وكاش الأصول، طابور ترميز وحصص للوسائط	متوسط	أسابيع	لا شيء
اختبارات ودجات للخريطة والطلبات ونموذج العرض ومسار المنشئ	متوسط	أسبوع	لا شيء
فحص الصور والفيديو قبل النشر وحد يومي للمنشورات؛ صور متعددة للمنشور؛ تعليقات على منشورات الخريطة	متوسط	أسابيع	لا شيء
جلسات المستخدم (/me/sessions) وتغيير النك نيم مع إعادة التوجيه؛ حفظ موضع البث والنشر باسم الدائرة	منخفض	أسابيع	النواة

8.4 إعادة تنظيم المعلومات المقترحة

مبنية على تحليل التماسك (القسم 2.1) وليست مجرد إعادة تسمية:

1. **مجموعة التبويبات:** الرئيسية / الخريطة / الأماكن / المحادثات / أنا. تبويب «الأماكن» يجمع الدوائر التجارية (المحتوى الأساسي) وطبقة الخريطة والبحث؛ السوق يدخله كفتة «من الناس» (أو يأخذ تبويماً خاصاً إن قرر المالك أن السوق هو المنتج الرئيسي)؛ الفعاليات داخل الأماكن/الاستكشاف مع زر «أنشئ فعالية».
2. **تنزيل المجتمعات (vessels)** من التبويب الرئيسي إلى قسم ثانوي داخل «الأماكن» أو الرئيسية، مع إعادة تسميتها «مجتمعات» بحسب المسرد.
3. **صفحة «طلباتي» واحدة** بأربعة تبويبات: مشتريات السوق / حجوزات الأماكن / تذاكر / مبيعاتي، تغذيها جداول الطلبات الثلاثة، وتحلّ محل مداخل MyBookingsPage و OrdersPage و MyTicketsPage؛ صفوف كشف المحفظة تربط إليها بالمرجع ref.
4. **لوحة «نشاطي» واحدة** للبائع/المضيف/صاحب الدائرة: عروض السوق + كتالوج الدائرة + الفعاليات + الإعلانات المميزة، بدل ثلاث لوحات.
5. **ترقية البائع بالمرجع لا بالنسخ:** قسم «من السوق» في الدائرة التجارية يعرض عروض البائع الحية بمسار طلب واحد (الضمان)، أو حذف الترقية.
6. **قائمة القطع الصريحة:** قصة النواة «لحظة» و«دبوس» من قائمة نقطة الخريطة؛ نوع biz_post «عرض» (يُدمج في offers.js)؛ شريحة biz في الأمنيات حتى يوجد قلب على صفحة الدائرة؛ أوامر الدردشة pay و send و split / خلف المفتاح التنظيمي؛ البائعون التجريبيون المبدورون.
7. **الحواف الناقصة:** روابط /l و /p/ العميقة، أهداف إشعارات biz/post_like /meet_accepted /market_dispute ، صفوف الدوائر القابلة للنقر في الإشعارات، رابط من العرض إلى دائرة البائع، تنبيهات الأمنيات إلى الصنف نفسه.

8.5 طلبات إلى النواة (خارج المستودع)

هذه لا يمكن إصلاحها من هذا المستودع وتحتاج تعديلاً في /opt/naslife/src :

الطلب	ما يفتحه في المستودع
مسار تغيير كلمة سر بكلمة السر الحالية يعيد عبارة استرداد جديدة (POST /me/password)	تغيير كلمة السر للحسابات القديمة بلا عبارة (3.2)
حجب /presence/:id لغير الأصدقاء عندما is_public=false	وعد «ملف خاص» (3.2)
استشارة chat_mutes قبل إرسال Push للرسائل	كتم حقيقي (3.8)
DELETE /push/subscribe بالنقطة (endpoint) من أي مالك	إلغاء الاشتراك عند الخروج وتبديل الحساب (3.1)
clientId ومفتاح تكرار على POST /messages (upsert)	موثوقية الإرسال بلا رسائل مكررة (3.8)
قراءة بلا جلسة لـ GET /users/:handle و GET /market/:id (وما يلزم الروابط الضيحية)	صفحات عامة للعروض والملفات وتصفح الزائر (3.1, 3.6)
أسماء صريحة وثابتة لجداول users و blocks و reports و push_subscriptions (أو عقد موثّق)	إنهاء الاكتشاف بالتعبير النمطي في الإضافات الست (6)

9.1 كل المشكلات المؤكدة

الخطورة كما ثبتت بعد التحقق المزدوج. **ملاحظة على البندين الأولين:** رُشحا «حرجة» في خرائط الدوائر والبنية، لكن محققى الجاهزية والأمن والبنية صوّتوا «عالية» (الأول لأن المال تجريبي اليوم ومدير المنصة يستطيع الاسترداد تقنياً، والثاني لأنه كامن والإنتاج يشغل نسخة أقدم)، فأدرجا هنا بـ«عالية» مع وسم الترشيح، ويبقيان على رأس الأولويات.

العنوان	الخطورة	النوع	الدليل	الحل
الدوائر المبذورة بلا مالك تقبل دفعاً يذهب إلى لا أحد	عالية (رُشحت حرجة)	تنظيمي	server/business.js:743-747,312-318; business_seed.js:17,93,141	رفض الطلب عند owner_id IS NULL، وضع معلومات فقط، استرداد الطلبات القائمة
autodeploy.sh لا يحدّث الإضافات المنشورة	عالية (رُشحت حرجة؛ كامنة، الإنتاج يشغل نسخة أقدم)	تشغيلي	server/autodeploy.sh:35,41,43	سجل مُدار خارج مجلد التراجع، التخطي فشل مُخطر
رمز التسليم قابل للتخمين ويُقبل في paid	عالية	أمني	server/commerce.js:586,638-640,675	عدّاد محاولات وقفل، قبول الرمز من on_the_way
استرداد السوق بلا شرط حالة (مزدوج)	عالية	خطأ	server/commerce.js:646,663,687,693,700	UPDATE ... WHERE status IN (...) RETURNING
بيع فوق المخزون وحجز موعد مزدوج	متوسطة	خطأ	server/commerce.js:564,571-576,592-593	FOR UPDATE وخصم مشروط وفهرس فريد جزئي
تعارض أقفال التحويلات المتقابلة	متوسطة	خطأ	server/commerce.js:163-166,183	قفل الصفين بترتيب user_id ومعالجة 40P01
إلغاء الفعالية يفشل بخطأ خادم إن أنفق الإيراد، بلا تأكيد ويحدثات المنظم	عالية	خطأ	server/commerce.js:103-111,252-253,299-307; events_page.dart:103-108,189,213-220	حجز الإيراد، التقاط نقص الرصيد، استرداد للتذكرة، حوار ومنتهي مكان
الشحن التجريبي بنوع الحركة نفسه كمال البطاقة	عالية	تنظيمي	server/commerce.js:137-142; market_b.js:396	نوع test_topup ورفضه مع مفاتيح حية
مساران إداريان لسك الرصيد بلا تدقيق	عالية	أمني	server/commerce.js:137,145-152	حذفهما، سقف يومي وموافقة ثانية
المحفظة تناقض المسار التنظيمي (تحويلات بلا حد، حد أدنى عشرة ريالات)	عالية	تنظيمي	server/commerce.js:155-169; market_b.js:249; admin.js:139	إعدادات إطفاء وسقف PAY_MIN مئة ريال
استرداد المزوّد والاعتراضات لا تُعكس	عالية	تشغيلي	server/market_b.js:390-391	حالة عدم تطابق، خصم تعويضي، مطابقة ليلية
الحذف الإداري يحو الدفتر والطلبات وإجراءات البلاغات	عالية	تنظيمي/بيانات	server/admin.js:437-467	حذف ناعم مع تجهيل، منع عند رصيد غير صفري
أي حامل reports.act يوقف أي حساب	عالية	أمني	server/admin.js:520-527; team.js:44-53,62-63	الهدف من صف البلاغ واشتراط users.manage
صندوق بريد العضو غير فريد	عالية	أمني	server/team.js:95-98,232,278-280; inbox.js:122-126	فهرس فريد جزئي وأسماء محجوزة
الاسترداد يُخصم من مالك اللحظة لا ممن قبض له	عالية	بيانات	server/business.js:746,775,784,676-687,457-458	credited_to على الطلب

العنوان	الخطورة	النوع	الدليل	الحل
إهداء الكوبون غير ذري	عالية	خطأ	server/offers.js:303-314	عمل مخصص مع FOR UPDATE
/send يُصدّق بالمبلغ والوقت (تحويل واحد يصدّق عدة بطاقات)	عالية	أمني	server/chat_cards.js:197-202; commerce_api.dart:11	التحويل من الخادم بـ ref=messageId
روابط /l/ لا تفتح العرض	عالية	خطأ	share_links.dart:24-35; share.js:99-107	نوع listing في PendingLink
اكتشاف جدول الحظر يربط inbox_blocked (مؤكد حياً)	عالية	خطأ	server/safety.js:42,47-51; inbox.js:75	أسماء صريحة واستثناء جداول المستودع
لا نسخ احتياطي	عالية	تشغيلي	لا pg_dump في المستودع أو التوثيق	pg_dump ليلي خارج الخادم
النواة خارج المستودع ولا استعادة من git	عالية	تشغيلي	server/autodeploy.sh:47-59; لا server/index.js	نسخة للقراءة وعقد موثّق
لا سياسة خصوصية ولا شروط ولا موافقة	عالية	تنظيمي	lib/screens/login_page.dart:193-216	صفحتان وسطر موافقة
لا حذف ذاتي للحساب	عالية	تنظيمي	myspace_page.dart:163-181; admin.js:469-486	POST /me/delete بإعادة توثيق
الزائر: جدار دخول ولا عودة من شاشة الدخول	عالية	تجربة	lib/app/app.dart:66-70,256,281	«متابعة كزائر» وتصفح عام
فرع النشر = root ومدير؛ الإلغاء يُعاد	متوسطة	أمني	deploy.yml:106-109; admin.js:117-124,496-497	حماية الفرع، مستخدم نشر، جدول إلغاءات
القيد الفوري لمالك الدائرة ثم استرداد يهبط بالرصيد	متوسطة	منطق	server/business.js:746,312-318,784	حجز حتى الاستلام
النقاط لا تُعكس عند الاسترداد	متوسطة	منطق	server/business.js:744,783	نقاط سالبة عند الاسترداد
البذر يعيد المخزون والتفعيل عند كل إقلاع	متوسطة	بيانات	server/business.js:126-129,138-141,144	DO NOTHING أو seed_version
السينما والعبادة بلا تأكيد	متوسطة	تجربة	business_page.dart:1013-1026,831-845	ورقة تأكيد موحدة
مهلة الإلغاء غير مرئية والمنتج «حجز»	متوسطة	تجربة	business_page.dart:468,492,496	عرض «يمكن الإلغاء حتى»
المحرر لا يختار نوع الصنف	متوسطة	منطق	dashboard_catalog.dart:111,298	منتقي نوع وأيام
تقييم بلا شراء يسمح رد المالك	متوسطة	أمني	server/business.js:517-528	اشتراط طلب مكتمل
نقل الملكية بلا قبول	متوسطة	أمني	server/business.js:676-687	دعوة تُقبل
المطالبة بلا دليل وقبولها لا يمنح التوثيق	متوسطة	ثقة	server/business.js:435-473	قائمة أدلة وتوثيق تلقائي عند القبول
N+1 في الدوائر	متوسطة	أداء	server/business.js:299,486,495-496,813-814	تجميع بـ ANY(\$1)
لا دفتر تسوية للمالك	متوسطة	منطق	business_dashboard_page.dart:114,130	تبويب تسويات
أموال المشتري تتجمد بلا مهلة	متوسطة	منطق	server/commerce.js:663,613,710-718	إلغاء تلقائي للعالق
الدفع بلا رصيد متبقي ولا مسار شحن	متوسطة	تجربة	listing_page.dart:147,150,162-163	ورقة تصفية دفع

العنوان	الخطورة	النوع	الدليل	الحل
لا حساب ضمان في الدفتر	متوسطة	بيانات	server/commerce.js:589,625-626	قيود ضمان متوازنة أو رقم محتجز
العرض المرفوض blocked نهائياً	متوسطة	منطق	server/market_plus.js:448 commerce.js:493	حالة rejected قابلة للتعديل
تعين مندوب بلا موافقة	متوسطة	أمني	server/market_b.js:76-82	دعوة وقبول
رمز الجلسة في رابط الفاتورة وفي CSV الإداري (التصدير بـ finance.view)	متوسطة	أمني	commerce_api.dart:55 market_plus.js:400 admin_finance.dart:33-34 admin.js:603-614 team.js:26,66	رموز تنزيل قصيرة وربط التصدير بـ finance.manage
التقسيم في النزاع يُسقط العمولة ويترك العمود كما هو	متوسطة	بيانات	server/commerce.js:697-703 مقابل 691-696	عمولة نسبية وتحديث العمود
بائعون وهميون في الإنتاج (27) حساباً عبر register / بـ x-forwarded-for (مزيفة)	متوسطة	تنظيمي	server/market_seed.js:21- docs/market-:28,124 seed.md:1	وسم أو تطهير؛ حراسة البذر بمتغير بيئة
النزاع أحادي بلا تدقيق	متوسطة	تشغيلي	server/commerce.js:670-708	سحب ورد وسجل وتدقيق
إلغاء بلا تأكيد والبائع يلغي المسلم	متوسطة	تجربة	orders_page.dart:249,259,29 7-299	حوار وتقييد الحالة
النشر بلا تقدم ويفقد المسودة والموقع	متوسطة	تجربة	market_page.dart:348-366 orders_page.dart:94	بقاء النموذج ومنتقي موقع
السيوت لايت بلا استرداد والإيقاف جزئي	متوسطة	منطق	server/market_plus.js:288,3 06-308,335-339	تحديث كل الصفوف واسترداد نسبي
المواعيد بتوقيت الجهاز	متوسطة	خطأ	listing_page.dart:250 commerce.js:378-381	توليد بتوقيت الرياض
أسرار البوابة نصاً صريحاً والويبهاك اختياري	متوسطة	أمني	server/market_b.js:275,427	تشفير واشتراط السر
ثلاث نسخ من الدفتر (اثنان بالسالب) ولا مطابقة	متوسطة	بيانات	commerce.js:103 admin.js:157-163 business.js:228-234	وحدة واحدة و balance_after
سقف الشحن ثابت في العميل	متوسطة	خطأ	commerce_models.dart:34	إرجاع maxTopup من الخادم
التحويل بلا تأكيد ولا ماسح وشارة PIN وهمية	متوسطة	تجربة	wallet_page.dart:48,113- 139,146-151	ورقة تأكيد وإزالة الشارة
شحن البطاقة ينتهي بصفحة ثابتة	متوسطة	تجربة	market_b.js:419-421 wallet_page.dart:161-164	رابط عميق واستطلاع
لوحة المالية ناقصة وبالإنجليزية	متوسطة	تشغيلي	admin.js:589-591 commerce_models.dart:68-71	تبويبات إيراد ودفعات وملصقات
المستوى الافتراضي near غير منقذ	متوسطة	منطق	server/offers.js:55,66,183- 185	معاملة near كـ all
لا معاينة ولا رفض للعرض	متوسطة	تجربة	business_page.dart:305- 318,367	خطوة تسعير
البحث بلا فهارس من حرف واحد بلا دخول	متوسطة	أداء	server/search.js:63-72,75- 110	pg_trgm وحد أدنى حرفين
تعداد المستخدمين عبر بحث الأشخاص	متوسطة	أمني	server/search.js:64,67,75- 79	اشتراط الجلسة واستثناء المحظورين

العنوان	الخطورة	النوع	الدليل	الحل
أنواع قيم يرفضها الخادم والخطأ خام	متوسطة	خطأ	dashboard_offers.dart:261-offers.js:14,322,264	مواءمة وترجمة
سقوف العروض بلا قفل	متوسطة	خطأ	server/offers.js:101-120,154	FOR UPDATE على العرض
سقف الإشعار مشترك والمالك يُخبر بالوصول دائماً	متوسطة	منطق	server/offers.js:185-188 dashboard_offers.dart:501	فصل حسب النوع وعرض العدد
first-order خام ونشط في «عروضي»	متوسطة	تجربة	offers.js:117-118,277 offers_page.dart:192	ترجمة الرموز
عروض الحضور تعتمد على طلب موقع منتصف الدفع	متوسطة	تجربة	business_page.dart:365-367	طلب الموقع عند فتح الصفحة
شريط حفظ البحث على الأشخاص والدوائر وإعادة حفظ صامته	متوسطة	تجربة	search_page.dart:94,382-384	إخفاء الشريط وتوست «حَدَّث»
عروض N+1	متوسطة	أداء	server/offers.js:216-233,272-276	تجميع
الهدايا تتجاهل الحظر والإيقاف	متوسطة	أمني	server/offers.js:292-318	فحص naslifeBlockedIds
/pay غير ذري	متوسطة	خطأ	server/chat_cards.js:219-238	ادعاء الصف قبل التحويل
/send ينقل المال قبل الرسالة	متوسطة	منطق	chat_thread_page.dart:578-596	التحويل بعد معرفة المعرف
بلاغات المحتوى بلا لوحة	متوسطة	تشغيلي	server/safety.js:36-40,173-179	تبويب في البلاغات
اكتشاف جدول البلاغات غير حتمي (يربط content_reports حياً)	متوسطة	تشغيلي	admin.js:36,62-64 notify.js:83-87	اسم صريح
الإخفاء التلقائي قابل للتشديد	متوسطة	أمني	server/safety.js:61,158-171	حد يومي وعمر حساب
مبلغ الطلب غير مرتبط بنص الرسالة	متوسطة	منطق	server/chat_cards.js:186-193	عرض البطاقة من الطلب فقط
بطاقة ميتة عند فشل التسجيل	متوسطة	تجربة	chat_thread_page.dart:611-618,686-688	إعادة محاولة وتسجيل
الكتم لا يكتم Push	متوسطة	تجربة	server/safety.js:72	مزامنة الكتم مع Push أو إعادة التسمية
نحو عشرين نوع إشعار بلا وجهة	متوسطة	تجربة	lib/core/notify_open.dart:37-103	تغطية كل نوع واختبار
نقر Push والتطبيق مفتوح لا يفتح شيئاً	متوسطة	خطأ	web/push_sw.js:17-23 notify_providers.dart:41-44 hashchange لا	مستمع hashchange أو postMessage من SW لا
المنشورات المخفية لا تُستعاد	متوسطة	منطق	naslife_api.dart:167	قائمة «المنشورات المخفية»
حذف الرسالة بلا تأكيد والملف يبقى	متوسطة	تجربة	chat_thread_page.dart:992,1025-1034	حوار ومسار حذف الملف
وسائط عامة دائمة بلا حصص	متوسطة	بيانات	server/chat_tools.js:24-28,148,184,222	حصّة يومية وسياسة احتفاظ
فلتر الكلمات في العميل ومطابقة جزئية	متوسطة	منطق	server/safety.js:17-27	حدود كلمات وتحديث دوري

العنوان	الخطورة	النوع	الدليل	الحل
مال الدردشة P2P تحت السؤال التنظيمي	متوسطة	تنظيمي	server/chat_cards.js:219-239	خلف إعداد مطلقاً
طلب الموقع بلا شرح	متوسطة	تجربة	home_page.dart:139 location.dart:18-19	طلب من فعل صريح
الخروج لا يلغي Push	متوسطة	أمني	app_state.dart:169-174	unsubscribe في logout
«ملف خاص» لا يحترمه البحث	متوسطة	بيانات	server/search.js:75-79 share.js:94-95	LEFT JOIN profiles
صفوف الدوائر في الإشعارات مينة والقائمة مقصوفة	متوسطة	تجربة	notifications_page.dart:48,81-96	onTap وترقيم
السحب للتحديث ناقص	منخفضة	خطأ	home_page.dart:33-41	إبطال المزودات الأربعة
الزائر و«مراسلة»	متوسطة	تجربة	user_profile_page.dart:101 client.dart:203,261-263	ورقة الدخول للأفعال
العبارة السرية بالبريد	متوسطة	أمني	server/auth_alias.js:115-131,182-186	عرضها في التطبيق فقط
لا استعادة بالعبارة عند الدخول	متوسطة	منطق	login_page.dart:10 auth_alias.js:219,292-301	وضع استعادة جديد
تغيير كلمة السر مستحيل بلا عبارة	متوسطة	منطق	server/auth_alias.js:272-273	مسار في النواة
الجلسة المنتهية لا تُعالج أثناء الاستخدام (الرمز في localStorage بلا انتهاء ظاهر)	متوسطة	خطأ	client.dart:259-266 app_state.dart:94-99 session.dart:107-128	معالج 401 عالمي وإعادة التحقق عند عودة التركيز
فشل localStorage = فشل دخول	متوسطة	خطأ	app_state.dart:123-126,136-143	catchError على الحفظ
احتلال البريد	متوسطة	أمني	server/auth_alias.js:85,175,197-201,318-319	عدم الحجب بعد يوم
تغيير البريد بلا إعادة توثيق	متوسطة	أمني	server/auth_alias.js:314-333	كلمة السر وإشعار العنوان القديم
تعداد الحسابات عبر /auth/forgot	متوسطة	أمني	server/auth_alias.js:211-225	رد موحد
قص كلمة السر غير متسق (الدخول/التسجيل يقضان؛ التعيين/التغيير/تفعيل الاستعادة لا)	متوسطة	خطأ	client.dart:113,141,154,163 myspace_page.dart:678,744	دالة واحدة أو عدم القص إطلاقاً
تغيير كلمة السر بلا حقل تأكيد	منخفضة	تجربة	myspace_page.dart:659-676	حقل تأكيد
مفتاح التشفير يفشل بصمت	متوسطة	تشغيلي	server/auth_alias.js:30-38	رفض الإقلاع
الملف الخاص يكشف الحضور	منخفضة	أمني	user_profile_page.dart:42,84-85	إخفاء عند 403
الزائر لا يعود من شاشة الدخول	متوسطة	تجربة	app.dart:69,256,281	«متابعة كزائر»
تعديل المنشور يسمح الصوت	متوسطة	خطأ	publish_page.dart:128 map_posts.js:272	عدم إرسال audioUrl
نص اللوحة يُقتطع	متوسطة	خطأ	text_board.dart:96 map_posts.js:31	توحيد الحد

العنوان	الخطورة	النوع	الدليل	الحل
لا واجهة حجب/استعادة منشور	متوسطة	تشغيلي	map_posts.js:395-404	إجراءات في البلاغات
«متعدد» يهدر الصور	متوسطة	منطق	publish_page.dart:106-113,123	images JSONB أو الغلاف فقط
فيديو إلى السوق بلا صور	متوسطة	خطأ	publish_page.dart:96,144-147,239	تعطيل الواجهة للفيديو
روابط خارجية كوسائط	متوسطة	أمني	map_posts.js:103-109	مسارات ذاتية فقط
بيانات وملفات يتيمة	متوسطة	بيانات	map_posts.js:407,287-289	FK وكس
ترقيم OFFSET	متوسطة	منطق	map_posts.js:204-205,211	keyset
الميكروفون شرط الكاميرا	متوسطة	تجربة	camera_web.dart:49,55	فيديو فقط ثم صوت
التقدم التلقائي يقطع الصوت	متوسطة	تجربة	post_viewer.dart:73,100-106	إيقاف المؤقت أثناء التشغيل
رقمان للمشاهدات	متوسطة	بيانات	map_posts.js:297-300,338-340	تسمية وحساب داخل النافذة
موقع المنشور مضلل ومكشوف	متوسطة	تنظيمي	publish_page.dart:320 map_posts.js:116	دبوس وتعقيم
السعر بالأرقام العربية-الهندية	متوسطة	خطأ	publish_page.dart:126,145	استخدام parseSar
إلغاء المدير المبدور يُعاد	متوسطة	تشغيلي	admin.js:95-124,496-497	جدول إلغاءات
قسم السوق للفريق 403	متوسطة	خطأ	admin_shell.dart:32 market_plus.js:423-424	naslifeTeamAccess
الرابط العميق يفتح المالية	متوسطة	خطأ	notify_open.dart:96	indexWhere بالمفتاح
مرفق البريد ب token=?	متوسطة	خطأ	admin_inbox.dart:556-559 inbox.js:802-806	رابط موقع
CSAT عبر GET (ورمز الوبهوك العام في الاستعلام)	متوسطة	بيانات/CSRF	inbox.js:205,828-835 inbox.js:361-364	POST بتأكيد وانتهاء للرمز
تعطيل مدير قديم بلا أثر	متوسطة	منطق	team.js:137-138,272-277	إخفاء المفتاح أو ترحيل
إشعارات الإشراف للمديرين القدماء فقط	متوسطة	تشغيلي	notify.js:202-212	توسيع adminIds()
التدقيق ناقص وبلا تصفية	متوسطة	أمني	admin.js:690-695 inbox.js	تدقيق وتصفية
قيد إداري حتى مليون بنقرة	متوسطة	تنظيمي	admin.js:356-370	سقوف وموافقة ثانية
دليل المستخدمين خمسون فقط	متوسطة	تجربة	admin.js:322-333	ترقيم بمؤشر
الإزعاج عبر كل الصناديق	متوسطة	بيانات	inbox.js:531-545	تقييد بالصناديق المرئية
إزالة العضو تترك مراجع	متوسطة	تشغيلي	team.js:298-310	إعادة إسناد
مفتاح «الصيانة» لا يُنقَذ	متوسطة	تشغيلي	admin.js:154 server/lib/	تنفيذه أو إزالته
خادم واحد وإعادة تشغيل عند كل نشر	متوسطة	تشغيلي	autodeploy.sh:69,74-80	إعادة تشغيل بلا انقطاع لاحقاً
لا ترحيلات، جداول ودفتر مكررة، FK قليلة	متوسطة	بيانات	commerce.js:18-22 admin.js:31-32 business.js:75-79	schema_migrations ووحدة دفتر
الحزم حمراء (10 من 30) ولا CI	متوسطة	تشغيلي	deploy.yml:52- run.sh:9-13 55	إعادة ضبط ووظيفة اختبار

العنوان	الخطورة	النوع	الدليل	الحل
ثغرات اختبار الودجات (177) اختباراً في 40 ملفاً، لا شيء للخريطة والطلبات والمنشئ)	متوسطة	تشغيلي	لا اختبار للخريطة والطلبات والمنشئ	أولوية للشاشات الثقيلة
الأخطاء تُبتلع ولا مراقبة	متوسطة	تشغيلي	لا <code>setErrorHandler</code> : 29 موضع <code>.catch(() => {})</code>	معالج مركزي و <code>health/</code> عميق
N+1 وفهارس ناقصة	متوسطة	أداء	<code>commerce.js</code> :336,519-521,529 لا فهرس على <code>market_orders(buyer_id)</code>	تجميع وفهارس
استطلاع بلا <code>visibilitychange</code>	متوسطة	أداء	<code>notify_providers.dart</code> :11 <code>chat_thread_page.dart</code> :160-163	إيقاف عند الإخفاء
حزمة ويب ثقيلة تُعاد كل إصدار	متوسطة	أداء	<code>build/web/main.dart.js</code> <code>index.html</code> :52-59	<code>deferred</code> وكاش أصول
رفع بلا حصة و <code>ffmpeg</code> متزامن وكاش بلاطات غير ذرية	متوسطة	أداء	<code>chat_tools.js</code> :28,99,106,184 <code>tiles.js</code> :40	حصة وطابور وكتابة ذرية
أسرار نصاً صريحاً (ميسر، بريد، Anthropic) وبحث VAPID	متوسطة	أمني	<code>market_b.js</code> :275 <code>mail.js</code> :365-368 <code>inbox.js</code> :91,865 <code>notify.js</code> :118-136	تشفير ومفتاح صريح
اقتران <code>globalThis</code> وجيل تعويضية	متوسطة	جودة	<code>business.js</code> :70-71,146-171 <code>admin.js</code> :145	سجل صريح وإزالة الجسر
نقاط تشخيص عامة تكشف الداخل (الجدول، المسارات، أخطاء الدفع، <code>opsDir/webappDir</code>)	متوسطة	أمني	<code>notify.js</code> :242-245 <code>share.js</code> :108 <code>chat_tools.js</code> :171 <code>auth_alias.js</code> :363-368 <code>admin.js</code> :667 <code>profile.js</code> :27	حماية بجلسة إدارية
«دائرة» ثلاثة معاني والتبويب يعرض غير القابل للشراء	متوسطة	مصطلحات	<code>app.dart</code> :80,237 <code>search_api.dart</code> :61 <code>wishlist_api.dart</code> :35	المسرد (القسم 2)
أربع صفحات «طلباتي»	متوسطة	ازدواج	<code>my_bookings_page.dart</code> :17 <code>orders_page.dart</code> :34 <code>events_page.dart</code> :280 <code>my_offers_page.dart</code> :28	صفحة واحدة بتبويبات (8.4)
«عرض» خمسة منتجات	متوسطة	مصطلحات	<code>dashboard_posts.dart</code> :126 <code>posts_api.dart</code> :9 <code>search_page.dart</code> :148	المسرد
ترقية البائع تفرّق الكتالوج وإشعارها ميت	متوسطة	ازدواج	<code>market_b.js</code> :216-226 <code>notify_open.dart</code> :37-103	مرجع بدل نسخ وربط <code>biz</code>
المنشئ لا يصل للدوائر المجتمعية	متوسطة	تماسك	<code>publish_page.dart</code> :235-239 <code>post_editor_page.dart</code> :108	وجهة أو دمج نموذج
«لحظة» مفهومين وقائمة الضغط المطول مكررة	متوسطة	مصطلحات	<code>map_page.dart</code> :389-392,415,215	إزالة القصة والدبوس
السوق والفعاليات بلا تنقل دائم	متوسطة	تنقل	<code>home_page.dart</code> :106,108 <code>app.dart</code> :234-243	تبويب أو قسم أماكن
«طلب» أربعة معاني	متوسطة	مصطلحات	<code>business_page.dart</code> :496 <code>wanted_page.dart</code> :25 <code>chat_cards.dart</code> :271	<code>orderNoun</code> والمسرد

العنوان	الخطورة	النوع	الدليل	الحل
مفاهيم داخلية مكشوفة (paid = مؤگد، first-order)	منخفضة	تجربة	commerce_models.dart:437 offers_page.dart:192	تسميات وترجمة
ميزات مخفية (زائر، طلبات المشتري، نقاط بلا مستدع)	متوسطة	تنقل	app.dart:67-70 chat_cards.js:271-275 saved_search.js:150-157	إبراز أو إزالة
ثلاثة نماذج محتوى غير متوافقة	متوسطة	ازدواج	publish_page.dart:96,141 biz_community.js:72-77	حمولة منشور واحدة
لا توجيه URL	متوسطة	تنقل	app.dart:37-53	go_router
صفحة النشاط تخلط كل شيء بأزرار مال على المبدورات	متوسطة	تماسك	business_page.dart:143-194	وضعان: دليل ومتجر
المندوب بلا موافقة ولا مراسلة ولا أجر	متوسطة	شخصية	market_b.js:68-93 commerce.js:608-612	دور كامل
ميتا الرسائل والتفاعلات لأي معرف: أحداث المنشورات بلا فحص	منخفضة	IDOR	chat_tools.js:247-286 map_posts.js:294-302	فحص الطرفين والوجود
بيانات المستخدم لكل users.view بلا تسجيل	متوسطة	أمني	admin.js:284-318,337-353	تدقيق القراءة وقائمة سماح
محدد الدخول في الذاكرة لكل IP	متوسطة	أمني	auth_alias.js:54-63,80,196	عداد لكل حساب
رفع بلا حصه ونوع من الترويسة	متوسطة	أمني	chat_tools.js:184-191	حصه وفحص بايتات
تذاكر سَوى فوراً والإدارة تسمح بالسالب	متوسطة	مال	commerce.js:252-253,299-307 admin.js:640-641	حجز وقائمة سالب

9.2 المشكلات منخفضة الخطورة وبنود مسح التدفقات (مُعَلِّمة، لم تخضع للتحقق المزدوج)

البنود التي أضيفت من مسح التدفقات في هذه المراجعة (المُعَلِّمة + في أقسام 3) مُدرجة في نهاية هذا الجدول تحت «من مسح التدفقات».

العنوان	النوع	الدليل	الحل
قائمة المكتومين بمعرفات خام	تجربة	safety_page.dart:66	إرجاع الاسم
حذف بحث محفوظ أو أمنية أو الخروج بلا تأكيد	تجربة	saved_searches_page.dart:75-87 wishlist_page.dart:132-133 myspace_page.dart:175-179	تأكيد أو تراجع
مصطلحات القشرة غير متسقة (الخرائط/الخريطة، الحساب/الأمان، التنبيهات/الإشعارات)	تجربة	app.dart:80 auth_alias.js:125 notifications_page.dart:137	المسرد
ماي سبيس يخفي أخطاء تحميل الملف	تجربة	myspace_page.dart:41-45,150-152	ErrorState
كل التبويبات تُبنى عند الإقلاع والمؤقتات لا تتوقف	أداء	app.dart:81,227 notify_providers.dart:332-354	بناء كسول
إشعارات بلا وجهة تُعلم مقروءة بصمت	منطق	notify_open.dart:189-192	ورقة تفاصيل
الرئيسية جدة-المركز لكل مستخدم	منطق	providers.dart:441-443 home_page.dart:58-62	بذر bbox من الموقع
شاشة الدخول والبيان لا يطابقان التيم ولا lang/dir	تجربة	login_page.dart:33,255 web/index.html:2 manifest.json:6-7	ألوان Joy و lang="ar"

العنوان	النوع	الدليل	الحل
تكبير نص إجباري مع أحجام ثابتة صغيرة	تجربة	app.dart:44-51 home_page.dart:314,328	قصّ المقياس
رسالة مضللة بعد استنفاد محاولات الرمز	تجربة	client.dart:292 auth_alias.js:237	نص «اطلب رمزاً جديداً»
سقوط صامت إلى تسجيل بالنك نيم فقط	منطق	client.dart:114-117	إزالة السقوط
سباق تسجيل ينشئ حساباً بلا بديل	بيانات	auth_alias.js:178,184	فحص rowCount
حالة الحظر لا تظهر في الملف	تجربة	user_profile_page.dart:58-66,100-108	حالة «محظور»
نصوص ApiException خام في ماي سبيس	تجربة	myspace_page.dart:210,231,240	errText
مفتاح الخصوصية مقترن بطلب الحضور	تجربة	myspace_page.dart:130-160	بطاقة مستقلة
لا فهرس على lower(nickname)	أداء	auth_alias.js:163 ; share.js:90	فهرس تعبير
الزائر يرى أفعالاً لا تعمل	تجربة	user_profile_page.dart:101	توجيه للدخول
ملفات الصور اليتيمة لا تُحذف	بيانات	profile.js:36,43	كنس
كل حفظ تعديل يمدد الصلاحية	منطق	publish_page.dart:125 map_posts.js:274	إرسال ttlHours عند التغيير فقط
تغيير المرشح يترك PageView في مكانه	خطأ	feed_page.dart:118	jumpToPage(0)
عدّاد المشاهدات يُكتب على المنشور الخطأ	خطأ	post_viewer.dart:112-113	التحقق من المعرّف
إشعار الإعجاب لا يفتح شيئاً	تجربة	notify_open.dart:39-102	حالة post_like
«لحظة» ثلاثة مفاهيم ولا تصفية بالوسم	تجربة	map_page.dart:374-376,207	شرائح وسم
العارض يغلق نفسه بعد الأخير	تجربة	post_viewer.dart:117-123	إيقاف المؤقت
view/cta/contact بلا فحص وجود	أمني	map_posts.js:294-302,322-329	فحص الحالة وإزالة التكرار
كاش البلاطات غير ذري بلا سقف	تشغيلي	tiles.js:40,26	tmp. ثم rename
N+1 ومسح كامل في البث	أداء	map_posts.js:88-89,122,185-205	ANY(\$1) وفهرس
التوثيق يعد بمدة «دائم»	تجربة	docs/composer.md:52	تصحيح
فيديو إلى دائرة كصورة مكسورة	خطأ	publish_page.dart:141 biz_community.js:72-76	تعطيل الواجهة
لا مؤشر تقدم للرفع	تجربة	publish_page.dart:105-118,158-164	حفظ الروابط وشريط تقدم
شريط الرئيسية عالمي لا محلي	تجربة	posts_providers.dart:12	تمرير bbox
روابط صور خارجية للدوائر	أمني	business.js:392-396,555	ownMedia
محتوى مبذور قديم (أفلام، ساعات فارغة، مستشفيات)	بيانات	business_seed.js:70-96,232,141-187	info حتى المطالبة
حالات مجتمع الدائرة (مقروء وهي موقوفة، ردود بلا حد)	منطق	biz_community.js:180-183,222-223,291-312	حد وإخفاء رد
تأكيدات ناقصة للمالك وفقدان صامت للموقع	تجربة	dashboard_posts.dart:156-165 business.js:392	حوارات وخطأ حقل
لا docs/business.md	تشغيلي	docs/	كتابة المستند
الولاء يعدّ التاريخ السابق ويُعاد عند إعادة الإنشاء	منطق	offers.js:129-133,54,415	عدّ بعد البداية
أفعال مدمرة بلا تراجع في الأمنيات والبحوث والعروض	تجربة	wishlist_page.dart:132-133 dashboard_offers.dart:110-115	تراجع وتأكيد

العنوان	النوع	الدليل	الحل
تنبيهات الأمنيات بلا تبريد	منطق	wishlist.js:165-170	تبريد يوم
نوع biz في الأمنيات غير قابل للوصول	تجربة	wishlist_api.dart:160	قلب أو إزالة
تسميات غير متسقة بين البحث والأمنيات والعروض	تجربة	search_page.dart:147-150	المسرد
نقاط حالة تكشف المخطط وأعمدة ثابتة في offers.js	تشغيلي	offers.js:62 ؛ wishlist.js:197	حماية واكتشاف موحد
سباق نقطة تفتيش البحوث المحفوظة	بيانات	saved_search.js:71-80	التقاط الوقت قبل الاستعلام
سياسة أرقام التواصل تُتجاوز في الأسئلة والردود	منطق	market_plus.js:164-165,90-91,190-193	تطبيق hasContact
sold والنقاط لا تُعكس عند استرداد النزاع	بيانات	commerce.js:592-593,649-651	عكس عند الاسترداد
سعر فارغ ينشر مجاناً وتوافر غير صالح يُسقط	تجربة	listing_form.dart:77-78,203-206	سعر أو «مجاني»
مسارات تعيد 500 لمعرفات غير UUID	خطأ	market_plus.js:172,229,329,337,446	UUID_RE
لوحة السوق الإدارية بمعرفات خام	تجربة	admin_market.dart:105,112-114	منتقيات
السبوت لايت يخفي فشل جلب السعر	تجربة	seller_tools.dart:128-132	حالة خطأ
docs/market.md لا يطابق الكود	تشغيلي	docs/market.md	تحديث
النقاط تتراكم ولا شيء يستبدلها	منطق	wallet_page.dart:54	إخفاء أو قاعدة
سقف البطاقة الافتراضي مئة ألف	تنظيمي	market_b.js:248 ؛ admin.js:139	cardMaxTopup منفصل
/posts/hidden يعيد معرفات المنصة كلها	أداء	vessel_mod.js:100-107	تصفية من الخادم
صفحة الإشعارات: نص خام ولا ترقيم ولا حذف	تجربة	notifications_page.dart:328,337	errText وترقيم
صفحة الأمان بمعرفات وكتم منته	تجربة	safety_page.dart:66 ؛ safety_providers.dart:7-10	أسماء وإعادة تقييم
طلبات المال المعلقة بلا صندوق	تجربة	chat_cards.js:271-275	عرضها في الإشعارات
الواجهة تعرض أفعلاً بلا صلاحية	تجربة	admin_users.dart:101-121	AdminStatus.can()
زر حذف المهمة يظهر لمن يُرفض	خطأ	admin_tasks.dart:412	canDelete من الخادم
effort مع نموذج Haiku	خطأ	inbox.js:215-222	حذفه لهذا النموذج
رسائل مجدولة تعلق في sending	تشغيلي	inbox.js:618-626	إعادة الطابور
SMTP يرسل من عنوان الحساب لا المستعار	بيانات	mail.js:318-320	تخزين المرسل الفعلي وتحذير
حفظ الإعدادات كل شيء أو لا شيء ويقصّ بصمت	تجربة	admin_settings.dart:95 ؛ admin.js:673	حقول متغيرة فقط
روابط معاينة المدونة تموت مع كل نشر	تجربة	blog.js:219-221,433-443	حفظ المفاتيح وإعادة توجيه
إلغاء الفعالية الإداري يدفع للسالب	بيانات	admin.js:640-641	قائمة سالب
جِيل انجراف البيئة	تشغيلي	business.js:146-171 ؛ admin.js:145	إزالة الجسر
لا staging	تشغيلي	client.dart:74-76	بيئة ثانية
بقايا CSP وغياب HSTS وملفات Firebase	أمني	restore-caddy.sh:37 ؛ .firebaseerc	تنظيف وإضافة HSTS
كاتبان لفرع webapp-build وسكربت استعادة يُسقط HSTS الحي	تشغيلي	restore- ؛ deploy.yml:44-75 caddy.sh:37-57	كاتب واحد وإضافة الترويسات

9.3 تصحيحات وتخفيضات من التحقق المزدوج

هذه بنود لم تُرفض، بل صَحَّ المحققون أدلتها أو خَفَّضوا خطورتها؛ أدرجت في القوائم المؤكدة بالصياغة المصحَّحة.

العنوان الأصلي	التصحيح أو التخفيض
«الدفع من حوار بلا أي ملخص للطلب»	خُفِّضت: زر الطلب يعرض الإجمالي بعد الخصم والكمية والمتغير والموعِد على الشاشة نفسها (listing_page.dart:110-134)؛ ما ينقص فعلاً هو الرصيد المتبقي ومسار الشحن وإسقاط الكوبون غير المفحوص.
«الرئيسية تكشف تاريخ الانضمام للملفات الخاصة»	«عضو منذ» يعتمد على createdAt من profiles/:id الذي يعيد 403 للملف الخاص، فلا يُعرض؛ الكشف الفعلي هو حالة الاتصال والمعرِّف فقط (بند مؤكد بخطورة منخفضة).
«كل الرسائل تحيل المستخدم القديم إلى عبارة الاسترداد»	بريد الترحيب يحيل أولاً إلى «نسيت كلمة السر» بالبريد والعبارة كنسخة احتياطية (auth_alias.js:123-125)؛ الطريق المسدود محصور في حساب قديم بلا بريد مربوط؛ بقي البند بخطورة متوسطة.
«الشحن التجريبي لا يُميِّز إطلاقاً عن مال البطاقة»	شحن البطاقة يحمل ref بمعرف الدفعة وملاحظة مختلفة (market_b.js:394-396) فيمكن الفصل باستعلام؛ بقي البند عالياً لأن نوع الحركة والملخصات المالية لا تفرّق.
«سكربت النشر في الإنتاج يعمل بالنسخة المعطوية بإصلاحات سبتمبر لم تصل»	الخلل في المستودع مؤكد، لكن الاستنتاج عن الإنتاج تخميني ومرجّح خطؤه (زمن التشغيل الحي وتوثيق business.js:146-149 يشيران إلى نسخة أقدم تعمل)؛ خُفِّض من حرجة إلى عالية كقنبلة موقوتة عند أول إعادة تثبيت.
«الدوائر المبذورة بلا مالك – حرجة»	الآلية مؤكدة؛ خُفِّضت إلى عالية لأن المال تجريبي اليوم، وعيادات المستشفيات بسعر 0، ومدير المنصة يستطيع تقنياً الإلغاء والاسترداد (business.js:200-207, 833-848)؛ تبقى شرطاً قبل أي مفتاح حي.
«الحذف الإداري يكسر مساواة مجموع الدفتر بالأرصدة»	يحذف wallet_accounts مع wallet_tx معاً فلا تُكسر المساواة العالمية؛ الخسارة الفعلية هي أثر التدقيق وسجلات الأطراف الأخرى وسجلات ميسر، وهذا ما بقي في البند.
«الفشل التلقائي للكنس يُسقط التذكيرات إلى الأبد»	استعلامات الكنس قائمة على الحالة فتعالج ما استحق في التكة التالية؛ ما يُفقد هو النافذة أثناء إعادة التشغيل فقط.
«تحديثات الإقلاع في commerce.js:49-56 مسار فساد بيانات»	هذه تحديثات محروسة ب WHERE ومتكررة الأمان؛ حُذفت كمثال على خطر النسخ الاحتياطي وبقي الخطر الأصلي قائماً.
«send ينقل المال قبل الرسالة: إعادة المحاولة بعد عشر دقائق تُسجّل غير مؤكدة»	تصحيح جزئي: إعادة محاولة الفعالة تستدعي _send بلا onSent (chat_thread_page.dart:1012-1013) فلا تسجّل طلباً أصلاً؛ الجوهر (مال ذهب بلا بطاقة) مؤكد.

9.4 ما رُفض فعلاً عند التحقق

بندان فقط وُضعا في قائمة المرفوض، وأحدهما ثبت عند إعادة القراءة:

العنوان	الحكم
«اسم صندوق بريد العضو غير فريد ويستطيع الاستيلاء على الصندوق المشترك»	رُفِّضت الصياغة، وثبت الجوهر (أدرج في 9.1): الآلية مؤكدة للأسماء الشخصية (team.js:95-98, 232, 278) routeMailbox يفحص الاسم المشترك أولاً (inbox.js:122-126, 280)، لكن الادعاء بالغ في جزأين: inbox.js:125) فالبريد الوارد يبقى يصل للصندوق المشترك، ودور «المشرف» أدرج خطأ ضمن حاملي team.manage (يحملها المدير فقط، team.js:44-47). الأثر المتبقي: عضو يضبط اسمه على الاسم المشترك يظهر له كصندوقه الخاص في (mailboxes) فيقرأ خيوطه.
«ثلاثة محركات طلب بدلالات مال مختلفة خلف أزرار متطابقة ولا استرداد للمشتري في التذاكر»	رُفِّضت الصياغة، وجوهر الاختلاف مؤكد (الدائرة تُقيّد فوراً، السوق يحجز، التذاكر تُقيّد فوراً) ووُزِع على بنود مؤكدة أخرى. الصحيح بشأن التذاكر: لا استرداد يبدأه المشتري؛ مسار إلغاء المضيف يرد لكل حاملي التذاكر (server/commerce.js:293-304) لكنه يفشل بخطأ 500 إذا كان المضيف قد أنفق الإيراد – وهو بند 3.4/3.7 نفسه، لا تناقض معه. كذلك موضع زر السوق في listing_page.dart:134 لا 147: .